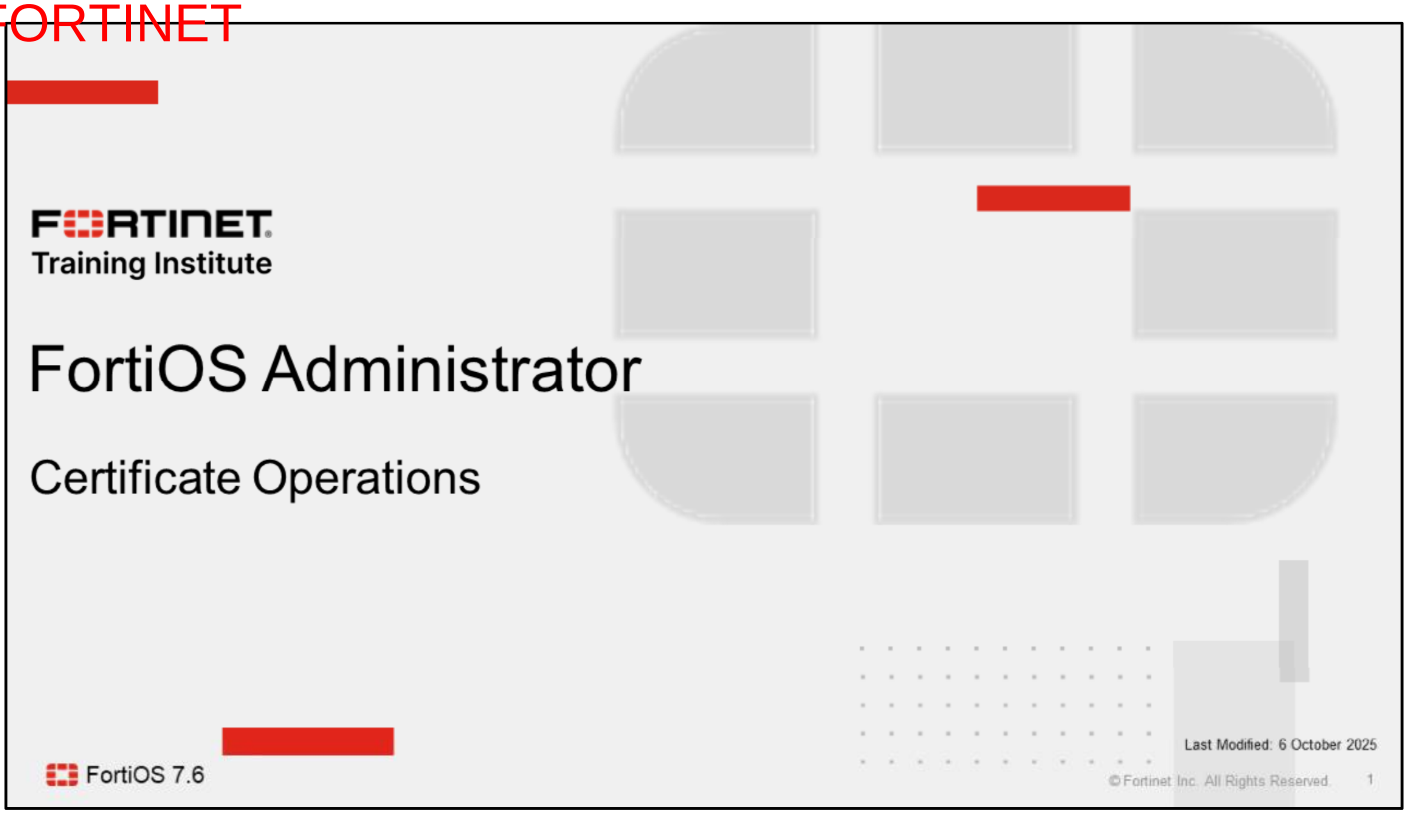
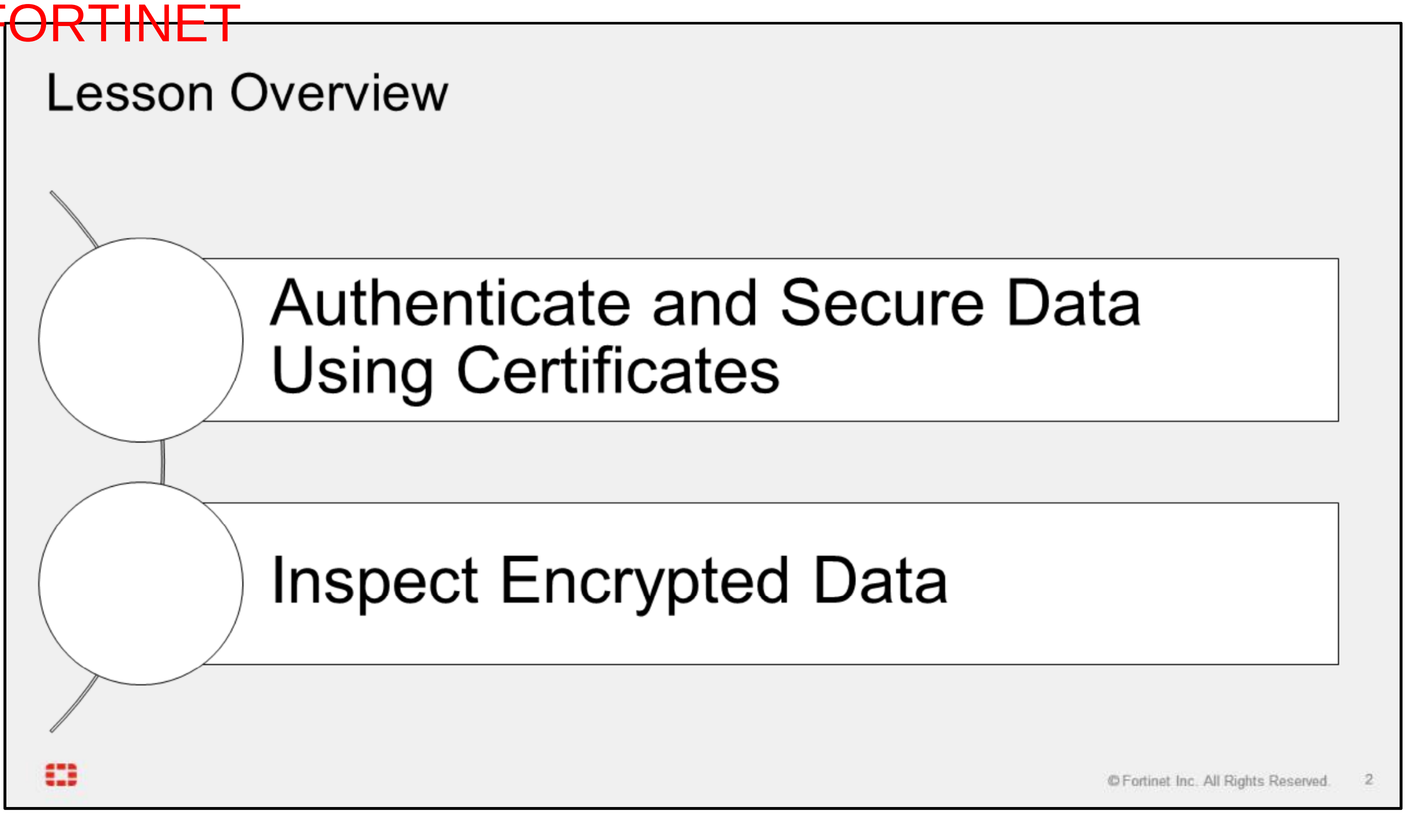
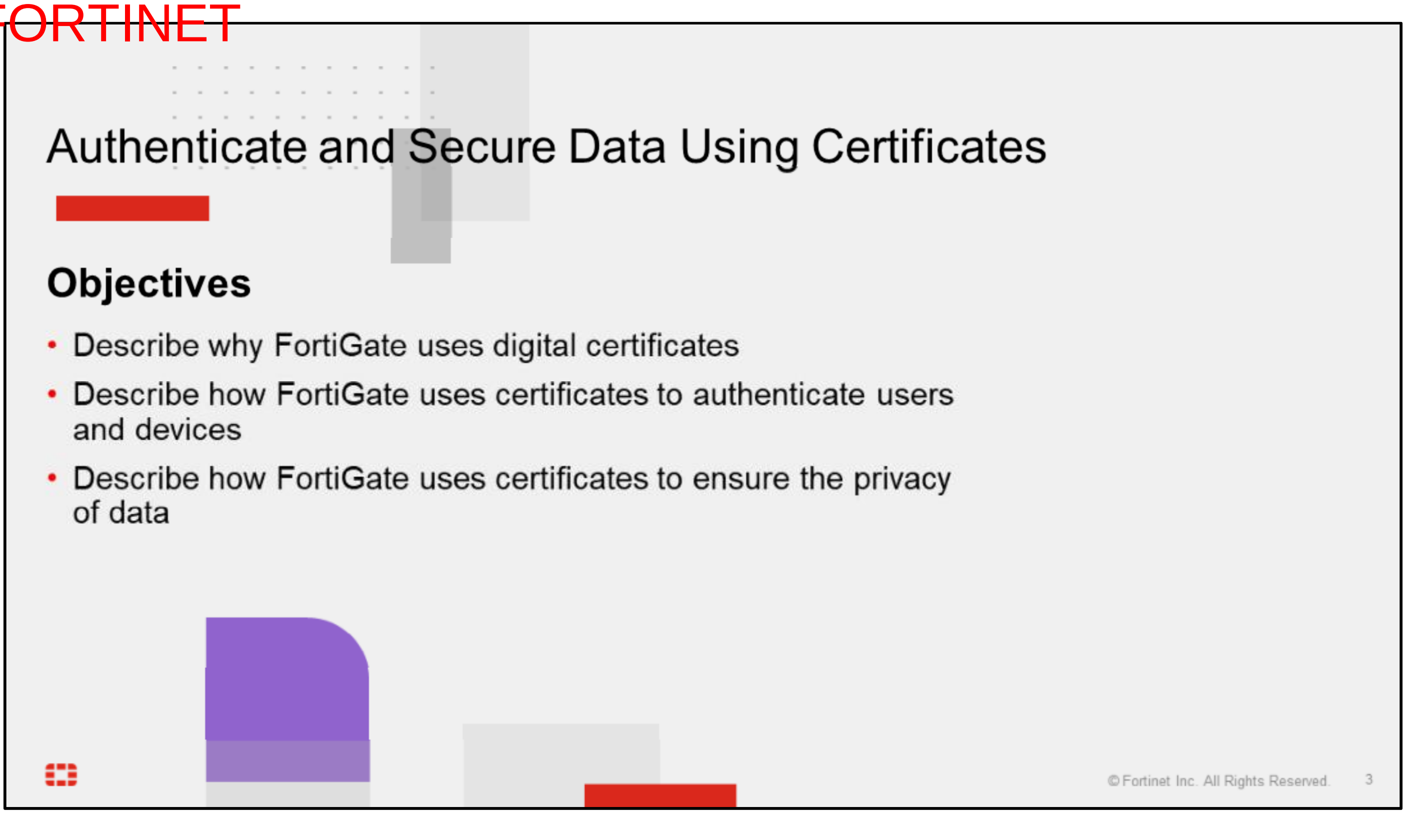


In this lesson, you will learn why FortiGate uses digital certificates, and how to configure FortiGate to use certificates for SSL and SSH traffic inspection.



In this lesson, you will learn about the topics shown on this slide.



After completing this section, you should be able to achieve the objectives shown on this slide.

By demonstrating a competent understanding of how FortiGate uses certificates, you will be better able to judge how and when certificates could be used in your own networks.

Digital Certificate

- What is a digital certificate?
  - A digital identity produced and signed by a certificate authority (CA)
  - Analogy: passport or driver's license
- Primary purposes
  - Authentication
  - Encryption and decryption
  - Integrity
- How does FortiGate use certificates to identify devices and people?
  - The **Subject** and **Subject Alternative Name** fields in the certificate identify the device or person associated with the certificate
- FortiGate uses the X.509v3 certificate standard

Field	Value
Version	V3
Serial number	0cacbf0403e86fc4ba3da5f26b...
Signature algorithm	sha256RSA
Signature hash algorithm	sha256
Issuer	Amazon RSA 2048 M02, Amaz...
Valid from	Sunday, 26 February 2023 02...
Valid to	Thursday, 28 March 2024 01:...
Subject	training.fortinet.com
Public key	RSA (2048 Bits)
Public key parameters	05 00
Authority Key Identifier	KeyID=c03152cd5a50c3827c7...
Subject Key Identifier	54c8bdc749bd966ac110f515d...
Subject Alternative Name	DNS Name=training.fortinet.c...
Enhanced Key Usage	Server Authentication (1.3.6....
CRL Distribution Points	[1]CRL Distribution Point: Distr...
Certificate Policies	[1]Certificate Policy:Policy Ide...
Authority Information Access	[1]Authority Info Access: Acc...
SCT List	v1, eecdd064d5db1acec55cb7...
Key Usage	Digital Signature, Key Encipher...
Basic Constraints	Subject Type=End Entity, Pat...
Thumbprint	5a09781b2bc9d911f18c2d285...

A digital certificate is a file or password used to authenticate a device, server, or user through cryptography and public key infrastructure (PKI). It is a digital document produced and signed by a CA.
It ensures that only trusted devices and users gain access to a network. It identifies an end entity, such as a person (for example, Joe Bloggings), a device (for example, `webserver.acme.com`), or thing (for example, a certificate revocation list). Another common use of digital certificates is to verify a website's legitimacy to a browser, known as an SSL certificate.

Certificates serve three primary purposes:
- Authentication: The common name (CN) or subject alternative name (SAN) field, or both are used to identify the device that the certificate is representing.
- Encryption and decryption: Private and public key pairs are used to encrypt and decrypt traffic.
- Integrity: Messages are hashed using a secret key known to both the sender and the receiver. The receiver uses the key to check the hash value and confirm the integrity and authenticity of the message data.

FortiGate identifies the device or person by reading the CN value in the **Subject** field, which is expressed as a distinguished name (DN). FortiGate could also use alternate identifiers, shown in the **Subject Alternative Name** field, whose values could be a network ID or an email address, for example. FortiGate can use the **Subject Key Identifier** and **Authority Key Identifier** values to determine the relationship between the issuer of the certificate (identified in the **Issuer** field), and the certificate.

FortiGate supports the X.509v3 certificate standard, which is the most common standard for certificates.

Why Does FortiGate Use Digital Certificates?

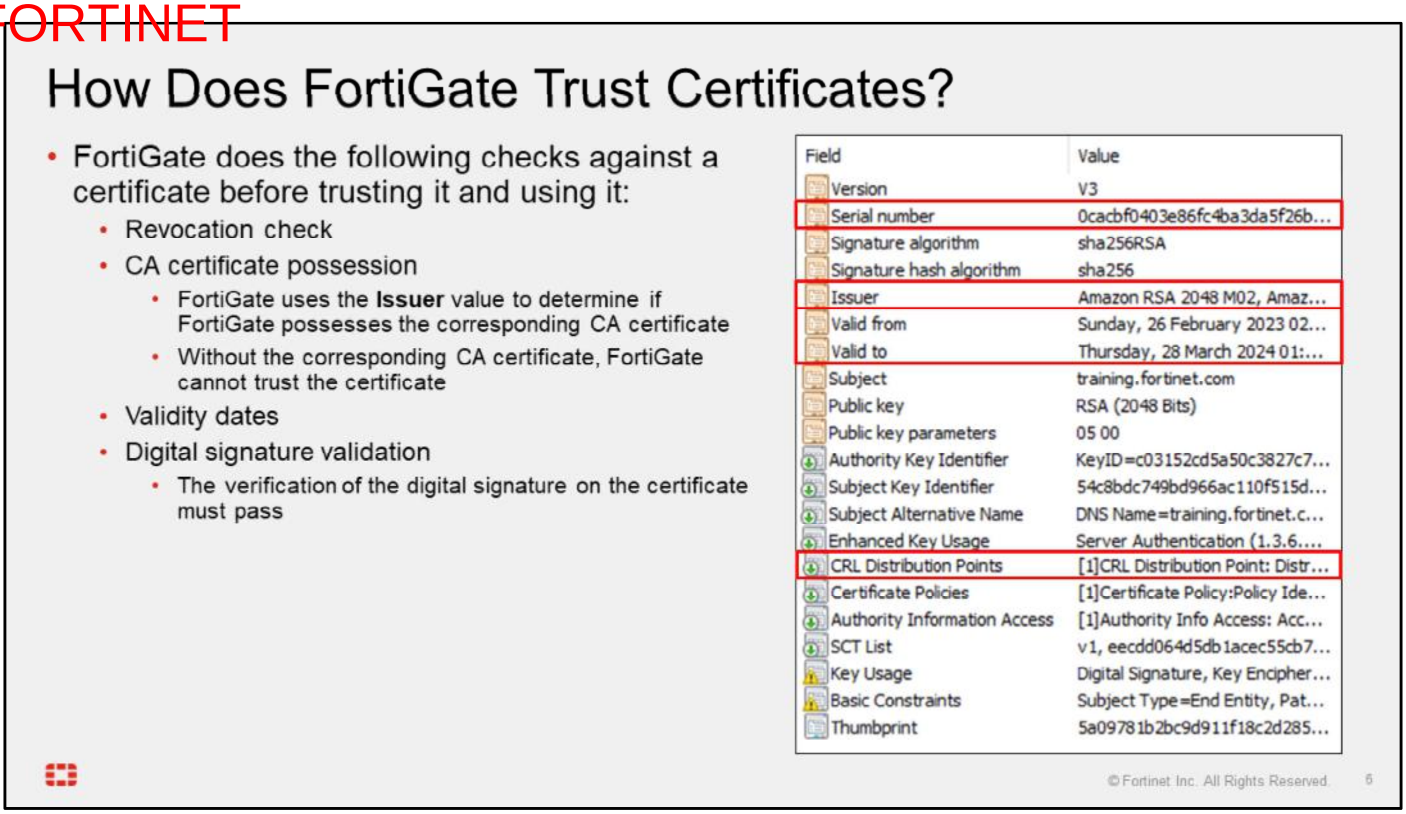
- Inspection
  - SSL/SSH and HTTPS traffic inspection
  - Inbound or outbound traffic through FortiGate
  - Traffic to and from FortiGate
- Privacy
  - Ensure privacy for exchanges with other devices, such as FortiGuard
- Authentication
  - User authentication for network access
  - User authentication for VPN connection
  - As second-factor authentication for FortiGate administrator

FortiGate uses digital certificates to enhance security in multiple areas.

FortiGate uses digital certificates for inspection, mainly outbound or inbound traffic inspection. If FortiGate trusts the certificate, it permits the connection. But if FortiGate does not trust the certificate, it can prevent the connection. How you configure FortiGate determines the behavior; however, other policies that are being used may also affect whether FortiGate accepts or rejects connection attempts. FortiGate can also inspect certificates to identify people and devices (in the network and on the internet), before it permits a person or device to make a full connection to the entity that it is protecting.

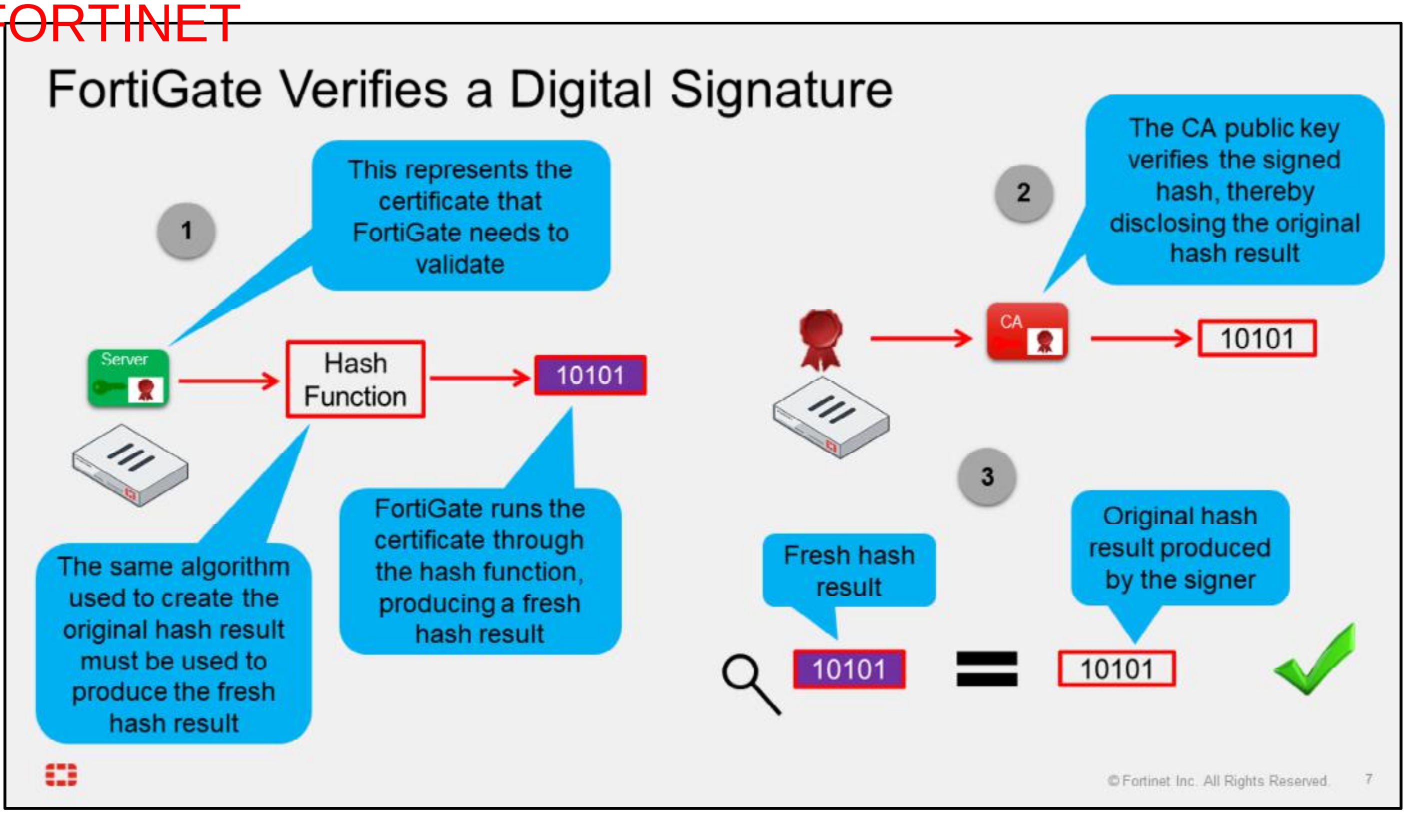
FortiGate uses digital certificates to enforce privacy. Certificates, and their associated private keys, ensure that FortiGate can establish a private SSL connection to another service, such as FortiGuard, or a web browser or web server.

FortiGate also uses certificates for authentication. Users who have certificates issued by a known and trusted CA can authenticate on FortiGate to access the network or establish a VPN connection. Administrator users can use certificates as a second-factor authentication credential to log in to FortiGate.



FortiGate runs the following checks before it trusts the certificate:

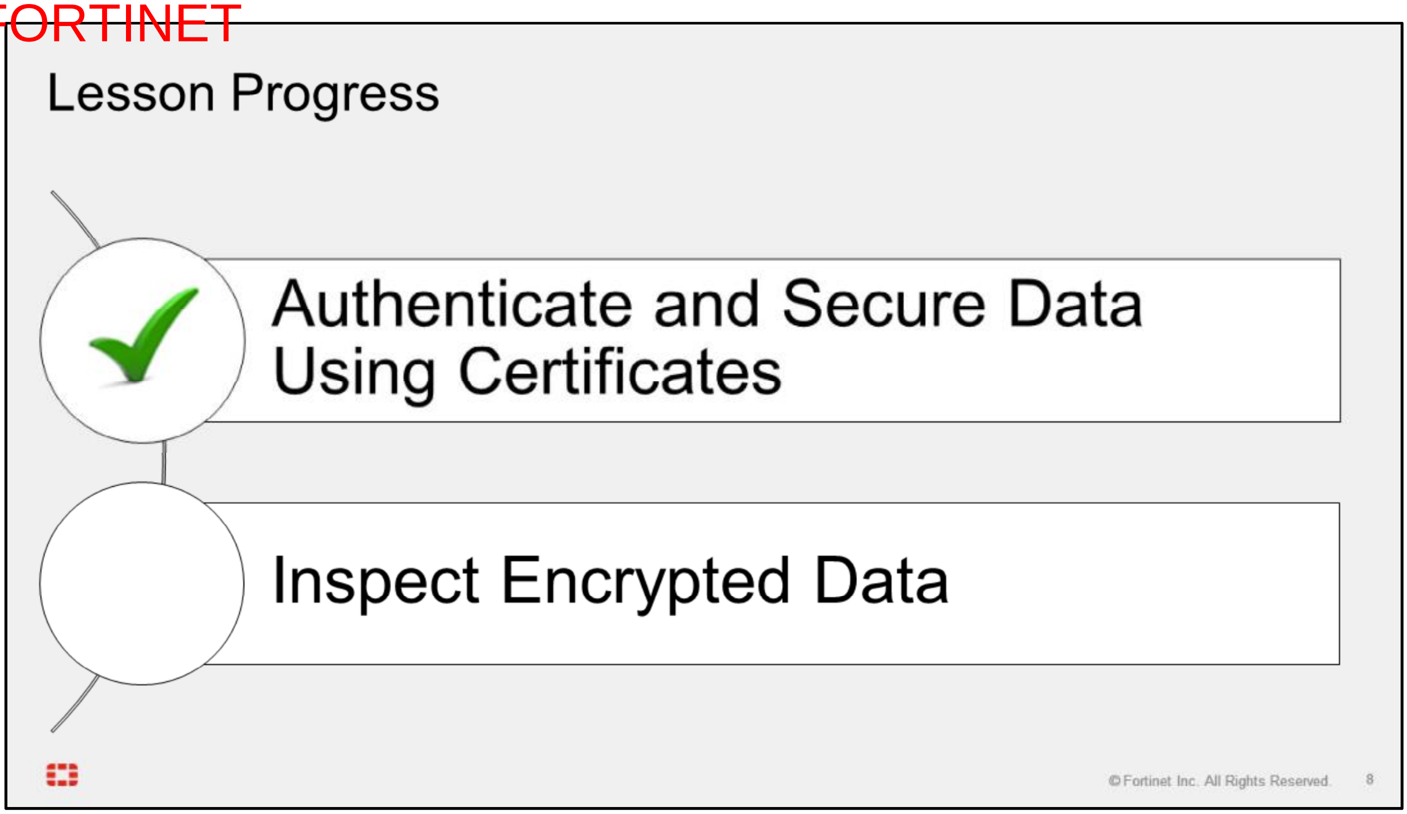
- Checks the certificate revocation lists (CRL) locally on FortiGate to verify if the certificate has been revoked by the CA.
    - FortiGate can download the relevant CRL, and check if the serial number of the certificate is listed on the CRL. If the certificate is listed, it means that it has been revoked, and it is no longer trusted.
- Reads the value in the **Issuer** field to determine if it has the corresponding CA certificate. Without the CA certificate, FortiGate does not trust the certificate.
- Verifies that the current date is between the **Valid From** and **Valid To** values. If it is not, the certificate is rendered invalid.
- Validates the signature on the certificate. The signature must be successfully validated.



When the CA generates a digital signature, it runs the content of the certificate through a hash function, producing a hash result, which is a mathematical representation of the data. This hash result is referred to as the *original hash result*. The CA signs the original hash result using its *private key*. The signed hash result is the digital signature. To validate a certificate, or any signed data, the digital signature and the hash result must be verified.

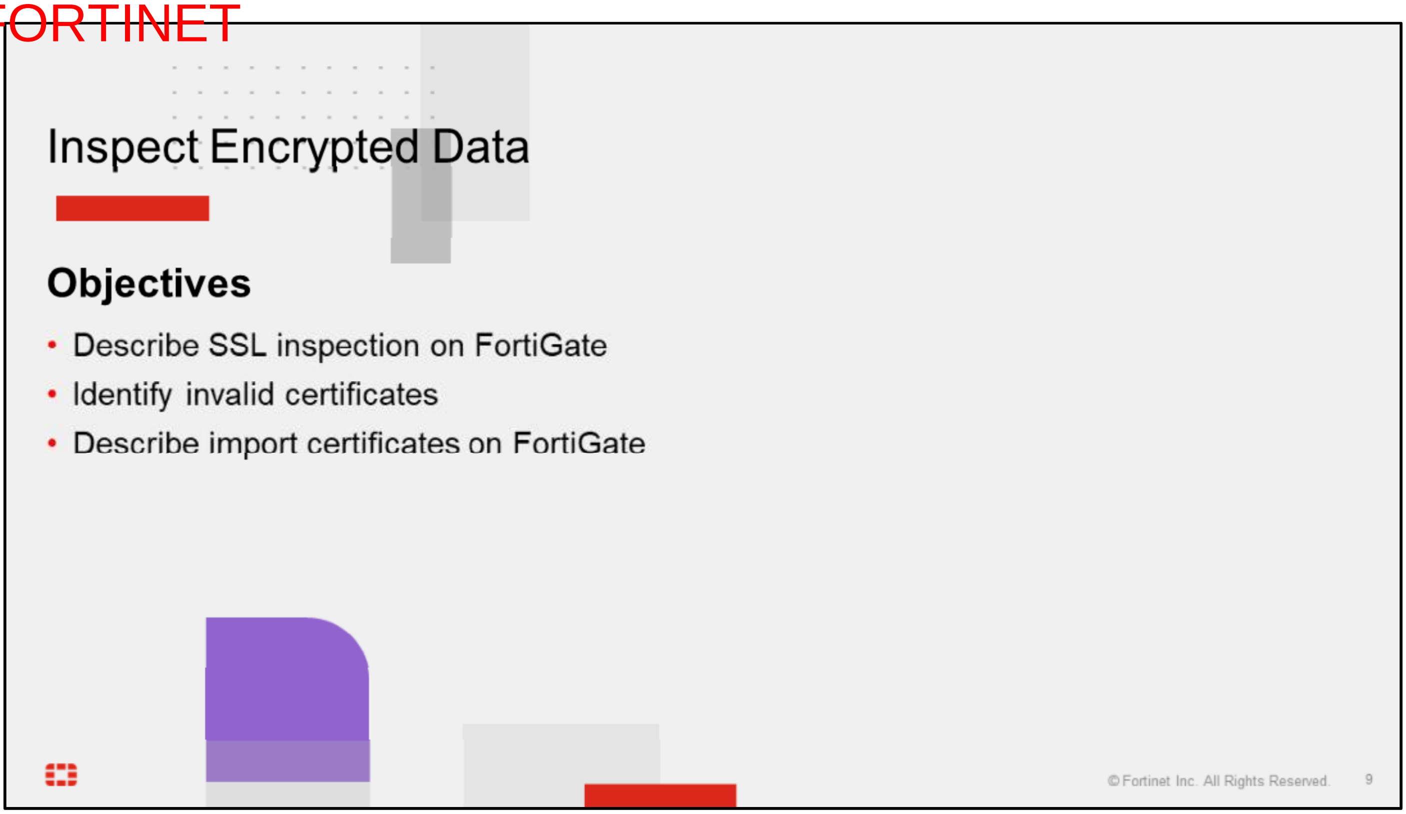
When validating a certificate, FortiGate runs the certificate through a hash function, producing a *fresh hash result*. FortiGate must use the same hash function, or hashing algorithm, that the CA used to create the digital signature. The hashing algorithm is identified in the certificate. Then, FortiGate verifies the digital signature using the CA *public key* and the same asymmetric algorithm that the CA used to sign the hash result. This process verifies the signature. If the key cannot restore the signed hash result, then the signature verification fails. If the verification succeeds, then it proves that the CA's private key signed the certificate. In the third, and final, part of the verification process, FortiGate compares the fresh hash result to the original hash result. If the two values are identical, then the integrity of the certificate is confirmed. If the two hash results are different, then the version of the certificate that FortiGate has is not the same as the one that the CA signed, and data integrity fails.

Sometimes the terms *encrypt* and *decrypt* are used to describe the digital signature process, but actually the language is more nuanced. The terms *sign* and *verify* more accurately describe digital signature processes because the purpose of digital signatures differs from the purpose of encryption. While the purpose of encryption is to obfuscate the input data so that it's unreadable, the purpose of digital signatures is to identify the signer, verify the integrity of the data, and sometimes to inextricably bind the data to the signer.



Good job! You now understand why and how FortiGate uses certificates to authenticate devices and people. You also understand how FortiGate uses certificates to ensure the privacy of data as it flows from FortiGate to another device, or from another device to FortiGate.

Now, you will learn how to inspect encrypted data.

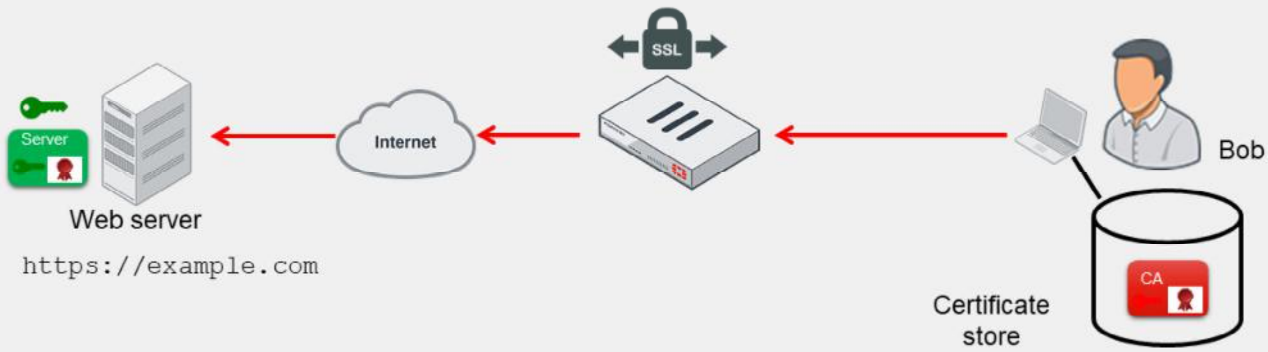


After completing this section, you should be able to achieve the objectives shown on this slide.

By demonstrating competence in understanding and configuring full SSL inspection and certificate inspection, you will be able to implement one of these SSL inspection solutions in your network.

Encrypted Traffic With No SSL Inspection

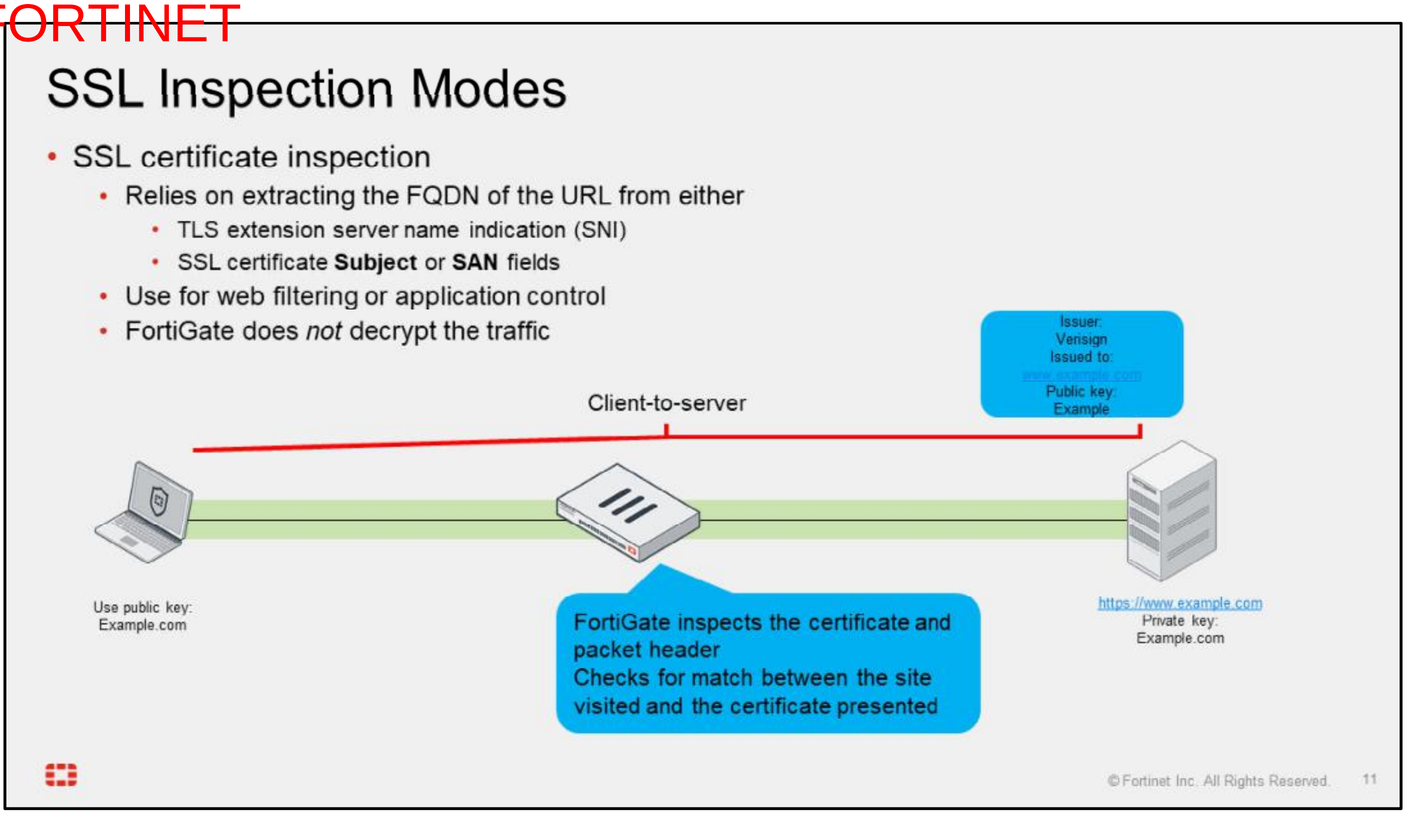
- Cloaked by encryption, viruses can pass through network defenses unless you enable full SSL inspection



While there are benefits to using HTTPS, there are risks associated with its use as well, because encrypted traffic can be used to get around normal defenses. For example, if a session is encrypted when you download a file containing a virus, the virus might get past your network security measures.

In the example shown on this slide, Bob connects to a site with a certificate issued by a legitimate CA. Because the CA is an approved CA, the CA verification certificate is in Bob’s certificate store, and Bob’s browser is able to establish an SSL session with the `example.com` site. However, unknown to Bob, the example.com site has been infected with a virus. The virus, cloaked by encryption, passes through FortiGate undetected, and enters Bob’s computer. The virus is able to breach security because full SSL inspection is not enabled.

You can use full SSL inspection, also known as deep inspection, to inspect encrypted sessions.



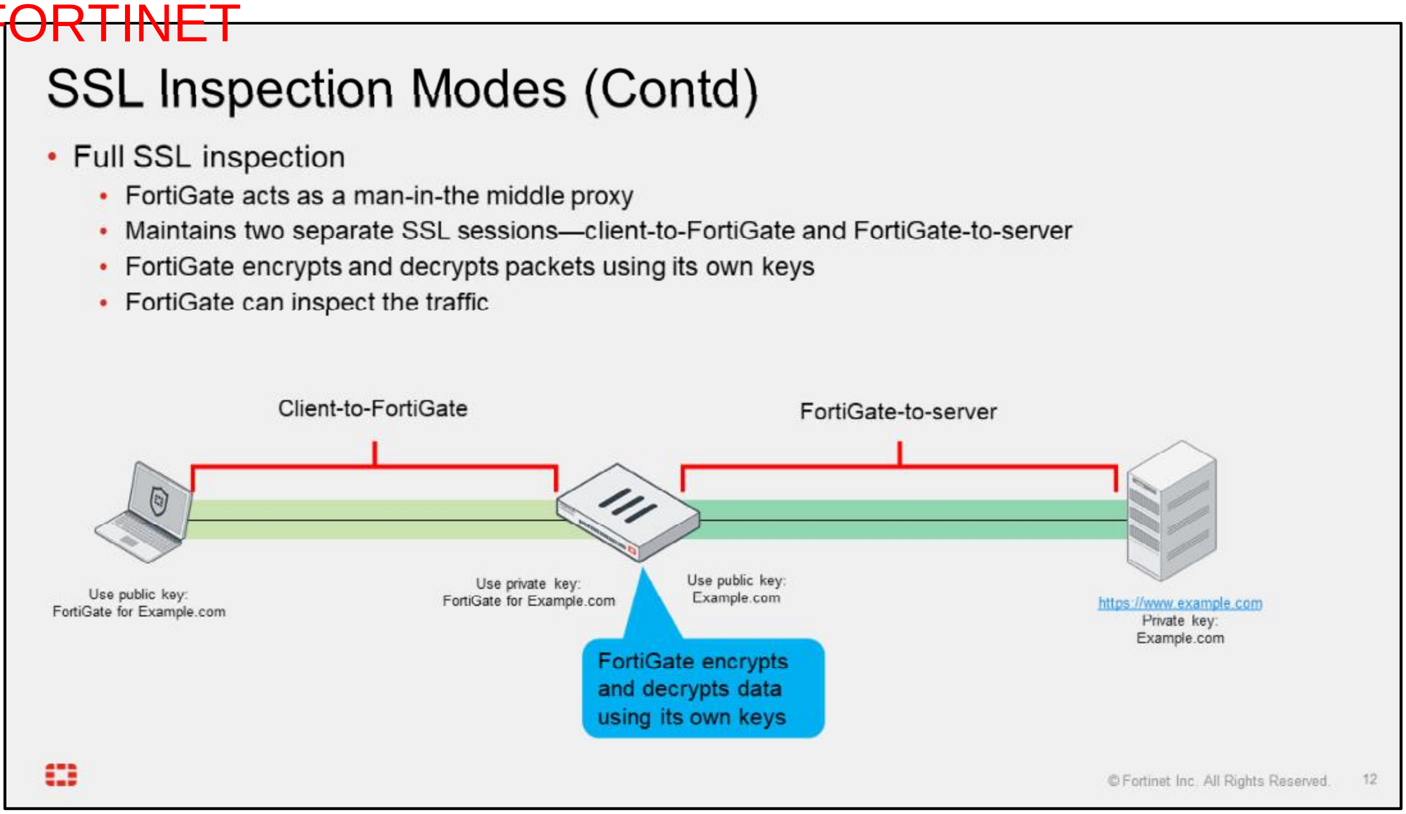
There are two SSL inspection modes: SSL certificate inspection and full SSL inspection.

When using SSL certificate inspection, FortiGate is not decrypting the traffic. During the exchange of hello messages at the beginning of an SSL handshake, FortiGate parses the server name indication (SNI) from the client Hello, which is an extension of the TLS protocol. The SNI tells FortiGate the hostname of the SSL server, which is validated against the **CN** or **SAN** field in the returned server certificate. If there is no SNI exchanged, then FortiGate identifies the server by the value in the **Subject** field or **SAN** field in the server certificate.

First, FortiGate tries to get the URL from the SNI field. The SNI field is a TLS extension that contains the complete URL that the user is connecting to. It is supported by most modern browsers.
If the SNI field is not present (because the web client may not support it), FortiGate proceeds to inspect the server digital certificate to get information about the URL or the domain.

The only security features you can apply using SSL certificate inspection mode are web filtering and application control. SSL certificate inspection allows FortiGate to identify the website visited or the application in use, and categorize it. You can, therefore, use it to make sure that the HTTPS protocol isn't used as a workaround to access sites you have blocked using web filtering.

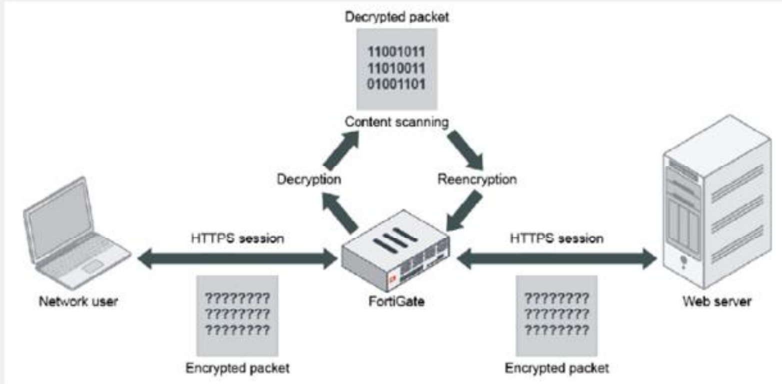
Note that while offering some level of security, certificate inspection does not allow FortiGate to inspect the flow of encrypted data.



You can configure full SSL inspection to inspect all of the packet contents, including the payload. FortiGate performs this inspection by proxying the SSL connection. Two SSL sessions are established—client-to-FortiGate and FortiGate-to-server. The two established sessions allow FortiGate to encrypt and decrypt packets using its own keys, which allows FortiGate to fully inspect all data inside the encrypted packets.

Full SSL Inspection (SSL Deep Inspection)

- Protect from attacks that use commonly used SSL-encrypted protocols
  - HTTPS
  - SMTPS
  - POP3S
  - IMAPS
  - FTPS
- FortiGate impersonates the recipient of the originating SSL session
  - Impersonates – decrypts
  - Inspects – blocks threats
  - Re-encrypts and sends to real recipient

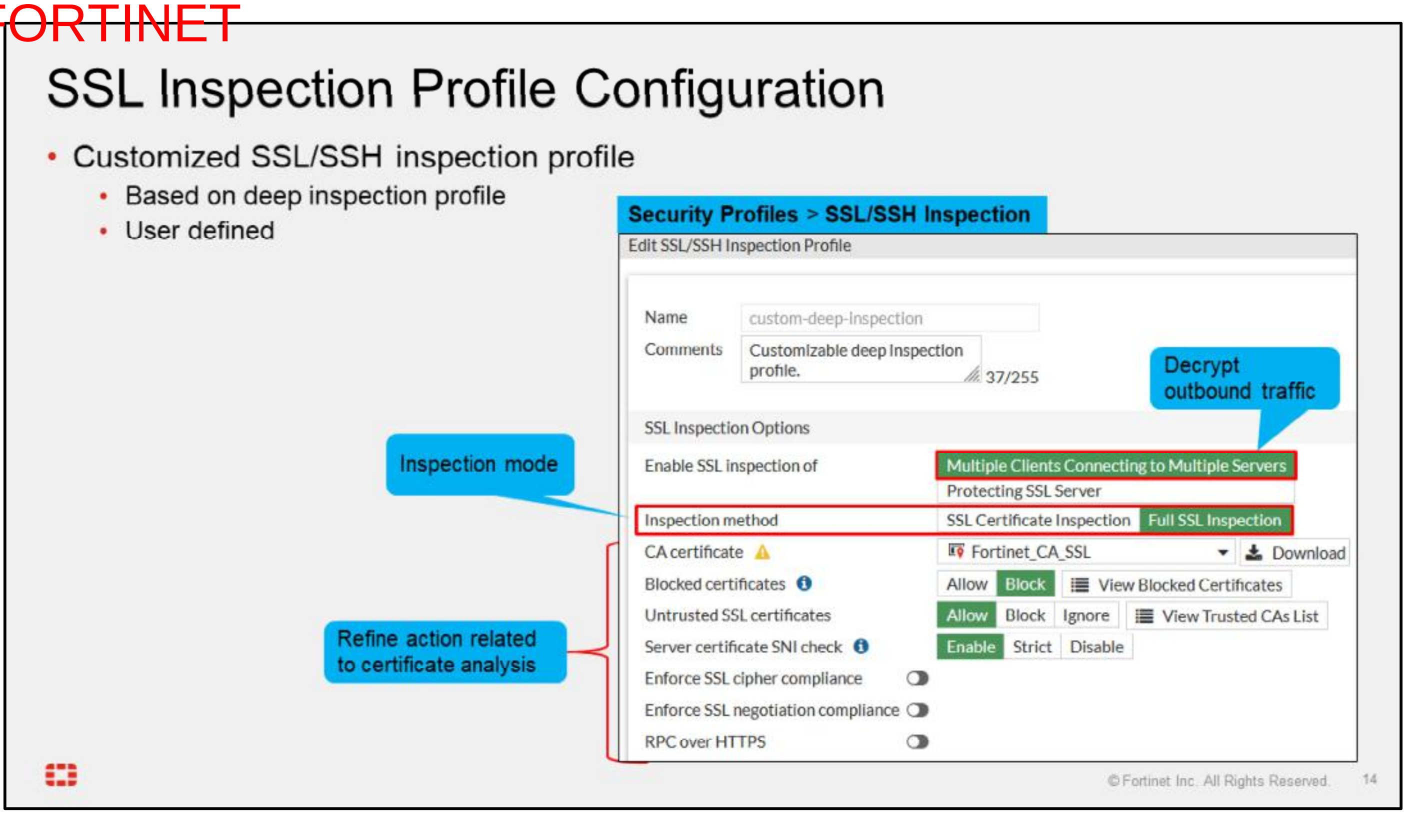


 13

Why we have to use deep inspection?

During an e-commerce session, you could download a file that contains a virus, or you might get a phishing email with an apparently harmless download that, when clicked, opens an encrypted session to a command and control (C&C) server and installs malware on your machine. These attacks may be able to bypass the safety measures on your network because the sessions are encrypted.

When you use deep inspection, FortiGate impersonates the recipient of the originating SSL session, and then decrypts and inspects the content to find threats and block them. It then re-encrypts the content and sends it to the real recipient. Deep inspection protects from attacks that use HTTPS and other commonly used SSL-encrypted protocols, such as SMTPS, POP3S, IMAPS, and FTPS.



On FortiGate, you can select the inspection mode applied at the firewall policy level. Three predefined SSL/SSH inspection profiles are available and correspond to the most common use cases.

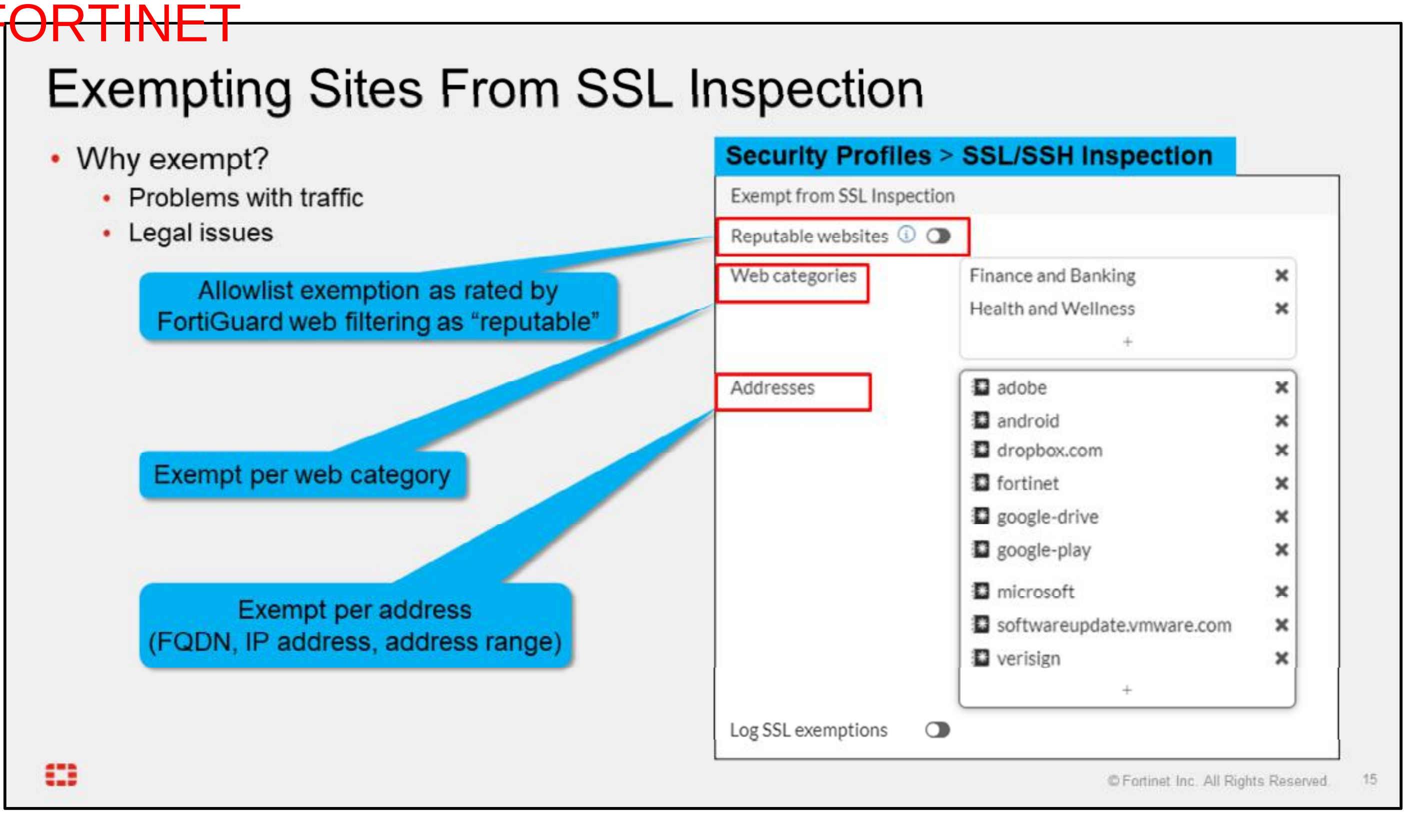
The profile applied by default when you create a new firewall policy is the self-explanatory no-inspection profile. Other predefined profiles available are certificate-inspection and deep-inspection, which applies full SSL inspection to outbound traffic.

The predefined certificate-inspection and deep-inspection profiles are read-only. If you want to adjust the profile parameters, you can use the predefined custom-deep-inspection profile or create a new, user-defined profile.

When you define a custom SSL/SSH profile, you can enable SSL inspection for outbound traffic with the parameter **Multiple Clients Connecting to Multiple Servers**, or for inbound traffic with the parameter **Protecting SSL Server**.

You can select the CA certificate used for traffic reencryption between FortiGate and the destination. By default, FortiGate uses the preloaded `Fortinet_CA_SSL` certificate.

You can also specify the action that FortiGate takes according to some certificate parameters or status. For instance, you can define whether you want to allow or block the traffic for untrusted or blocked certificates.



Within the full SSL inspection profile, you can also specify which SSL sites, if any, you want to exempt from SSL inspection. You may need to exempt traffic from SSL inspection if it is causing problems with traffic, or for legal reasons.

Performing SSL inspection on a site that is enabled with HTTP Strict Transport Security(HSTS), for example, can cause problems with traffic. Remember, the only way for FortiGate to inspect encrypted traffic is to intercept the certificate coming from the server and generate a temporary one. After FortiGate presents the temporary SSL certificate, browsers that use HSTS refuse to proceed.

Laws protecting privacy might be another reason to bypass SSL inspection. For example, in some countries, it is illegal to inspect SSL bank-related traffic. Configuring an exemption for sites is simpler than setting up firewall policies for each individual bank. You can exempt sites based on their web category, such as **Finance and Banking**, or you can exempt them based on their address. Alternatively, you can enable **Reputable websites**, which excludes an allowlist of reputable domain names maintained by FortiGuard from full SSL inspection. This list is periodically updated and downloaded to FortiGate devices through FortiGuard.

The predefined **deep-inspection** and **custom-deep-inspection** profiles exclude some web categories—**Finance and Banking**, and **Heath and Wellness**—and some FQDN addresses such as google-play, skype, or verisign. When using the **custom-deep-inspection** profile, you can add or remove sites from this list.

Invalid Certificates

- FortiGate can detect invalid certificates for a variety of reasons
  - Invalid certificates produce security warnings due to problems with the certificate details
- FortiGate can **Keep Untrusted & Allow**, **Block**, or **Trust & Allow** invalid certificates
- Selecting **Custom** allows the user to select the action for each reason

FortiGate can detect certificates that are invalid for the following reasons:

- Expired: The certificate is expired.
- Revoked: The certificate has been revoked based on CRL information.
- Validation timeout: The certificate could not be validated because of a communication timeout.
- Validation failed: FortiGate could not validate the certificate, or it is not yet valid.

When a certificate fails for any of the reasons above, you can configure any of the following actions:

- **Keep Untrusted & Allow**: FortiGate allows the website and lets the browser decide the action to take. FortiGate takes the certificate as *untrusted*.
- **Block**: FortiGate blocks the content of the site.
- **Trust & Allow**: FortiGate allows the website and takes the certificate as *trusted*.

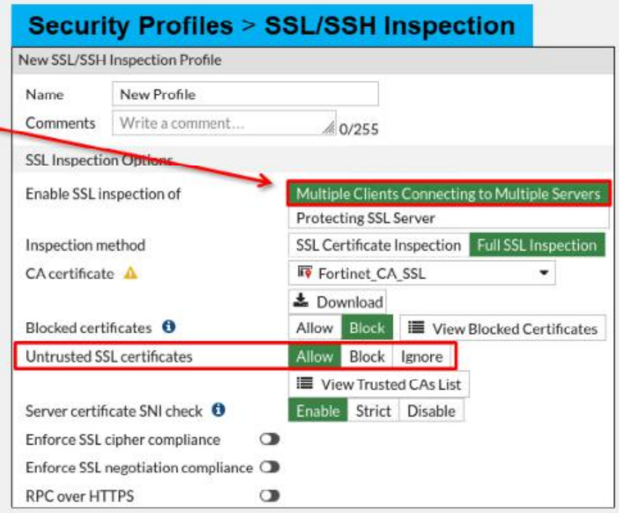
The certificate check feature can be broken down into two major checks, which are done in parallel:

- FortiGate checks if the certificate is invalid due to any of the four reasons described on this slide.
- FortiGate performs certificate chain validation based on the CA certificates installed locally and the certificates presented by the SSL server.

Based on the actions configured and the check results, FortiGate presents the certificate as either trusted (signed by `Fortinet_CA_SSL`) or untrusted (signed by `Fortinet_CA_Untrusted`), and either allows the content or blocks it. You can also track certificate anomalies by enabling the **Log SSL anomalies** option.

Untrusted SSL Certificates Setting

- Allow, block, or ignore untrusted certificates (only available if **Multiple Clients Connecting to Multiple Servers** is selected)
  - **Allow**: sends the browser an untrusted temporary certificate when the server certificate is untrusted
  - **Block**: blocks the connection when an untrusted server certificate is detected
  - **Ignore**: uses a trusted FortiGate certificate to replace the server certificate always, even when the server certificate is untrusted



 17

The browser presents a certificate warning when you attempt to access an HTTPS site that uses an untrusted certificate. Untrusted certificates include self-signed SSL certificates, unless the certificate is imported into the browser-trusted certificate store. FortiGate has its own configuration setting on the **SSL/SSH Inspection** profile, which includes options to **Allow**, **Block**, or **Ignore** untrusted SSL certificates.

When you set the **Untrusted SSL certificates** setting to **Allow**, and FortiGate detects an untrusted SSL certificate, FortiGate generates a temporary certificate signed by the built-in `Fortinet_CA_Untrusted` certificate. FortiGate then sends the temporary certificate to the browser, which presents a warning to the user indicating that the site is untrusted.

If FortiGate receives a trusted SSL certificate, then it generates a temporary certificate signed by the built-in `Fortinet_CA_SSL` certificate and sends it to the browser. If the browser trusts the `Fortinet_CA_SSL` certificate, the browser completes the SSL handshake. Otherwise, the browser also presents a warning message informing the user that the site is untrusted. In other words, for this function to work as intended, you must import the `Fortinet_CA_SSL` certificate into the trusted root CA certificate store of your browser. The `Fortinet_CA_Untrusted` certificate must *not* be imported.

When the setting is set to **Block**, and FortiGate receives an untrusted SSL certificate, FortiGate blocks the connection outright, and the user cannot proceed.

When the setting is set to **Ignore**, FortiGate sends the browser a temporary certificate signed by the `Fortinet_CA_SSL` certificate, regardless of the SSL certificate status—trusted or untrusted. FortiGate then proceeds to establish SSL sessions.

FortiGate Self-Signed CA Certificates

- By default, FortiGate uses a self-signed encrypting SSL CA certificate
  - `Fortinet_CA_SSL`
  - Not listed with an approved CA, therefore, by default, not trusted

- To avoid warnings on user devices
  - Install CA certificate `Fortinet_CA_SSL` as a trusted CA on user devices
  - Install a company CA certificate on FortiGate for SSL full inspection

 18

By default, FortiGate uses a self-signed CA certificate for the reencryption required by the SSL full inspection. Because the corresponding CA is not prepopulated in client device certificate stores, users will likely see certificate warnings for traffic flows protected by the full SSL inspection.

To avoid the warning, you can install the `Fortinet_CA_SSL` certificate as a trusted CA on the user devices. You can install it as part of the deployment process for all your company computers. Alternatively on FortiGate, you can install a CA certificate, used for traffic reencryption, that is signed by your company CA. This certificate will already be recognized as valid by your company devices.

The certificate used to re-encrypt the traffic after the SSL full inspection must follow some specific requirements, which you will learn about in this lesson.

Full SSL Inspection—Certificate Requirements

- Full SSL inspection requires that FortiGate act as a CA to generate an SSL private key and certificate
  - The CA certificate requires these two extensions to issue certificates:
    - cA=True
    - keyUsage=keyCertSign
- FortiGate can use:
  - The preloaded, self-signed `Fortinet_CA_SSL` certificate
  - A subordinate certificate issued by an internal CA
- The root CA certificate must be imported into the client machines

 19

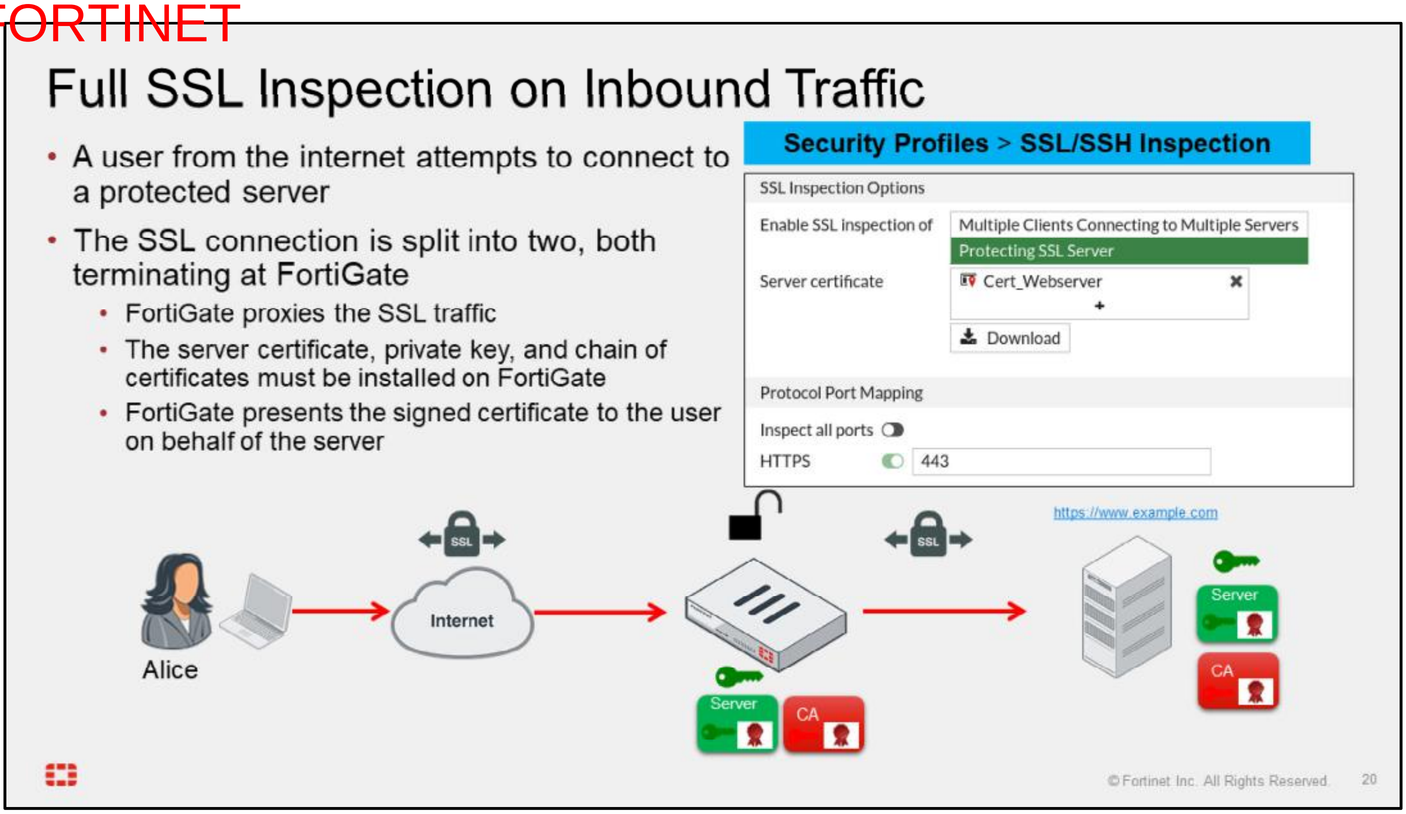
To perform full SSL inspection, FortiGate acts as a web proxy, and must act as a CA to reencrypt the traffic. The FortiGate internal CA must generate an SSL private key and certificate each time it needs to reencrypt a new traffic flow. The key pair and certificate are generated *immediately*, so the user connection with the web server is not delayed.

Although, from the user point of view, it appears as though the user browser is connected to the web server, the browser is in fact connected to FortiGate. To perform this proxy role and generate a certificate that corresponds to the server visited, the CA certificate must allow the generation of new certificates. To achieve this, it must have the following extensions: `cA` set to `True` and `keyUsage` set to `keyCertSign`.

The `cA=True` value identifies the certificate as a CA certificate. The `keyUsage=keyCertSign` value indicates that the certificate corresponding to the private key is permitted to sign certificates. For more information, see *RFC 5280 Section 4.2.1.9 Basic Constraints*.

All FortiGate devices come with the self-signed `Fortinet_CA_SSL` certificate that you can use for full SSL inspection. If your company has an internal CA, you can ask the CA administrator to issue a certificate for your FortiGate device. Your FortiGate device then acts as a subordinate CA. A subordinate (or intermediate) certificate is a certificate issued by the root CA that allows another device to create an endpoint (server or user) certificate on its behalf, as if it were issued directly from the CA itself.

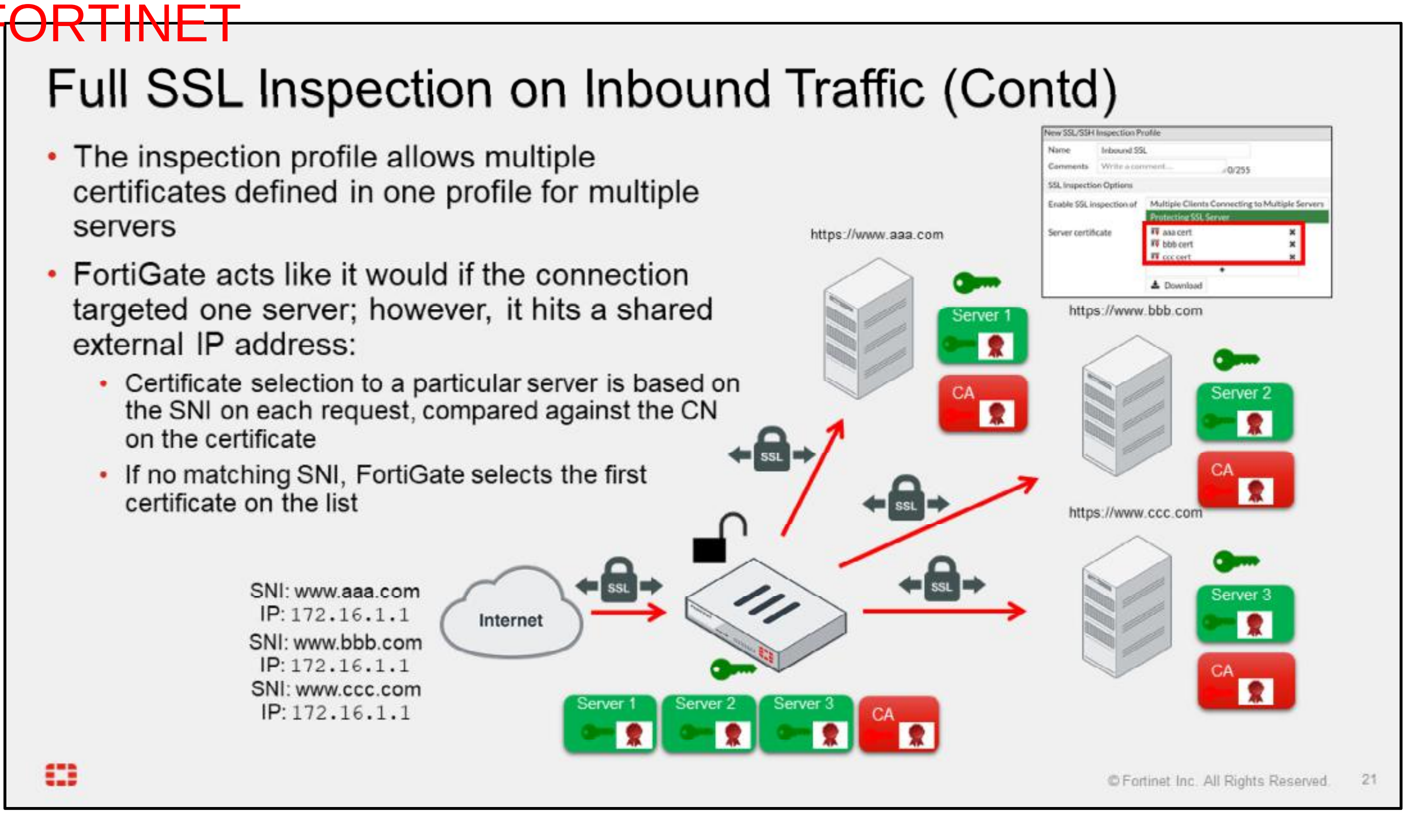
If you use the `Fortinet_CA_SSL` certificate, or a certificate issued by your company CA to trust FortiGate and accept reencrypted SSL sessions without warning, you must import the root CA certificate to your client devices.



In the example shown on this slide, FortiGate is protecting a web server. This is the second configuration option for full SSL inspection. When configuring the SSL inspection profile for this server, you must select **Protecting SSL Server**, import the server key pair to FortiGate, and then select the certificate in the **Server Certificate** field.

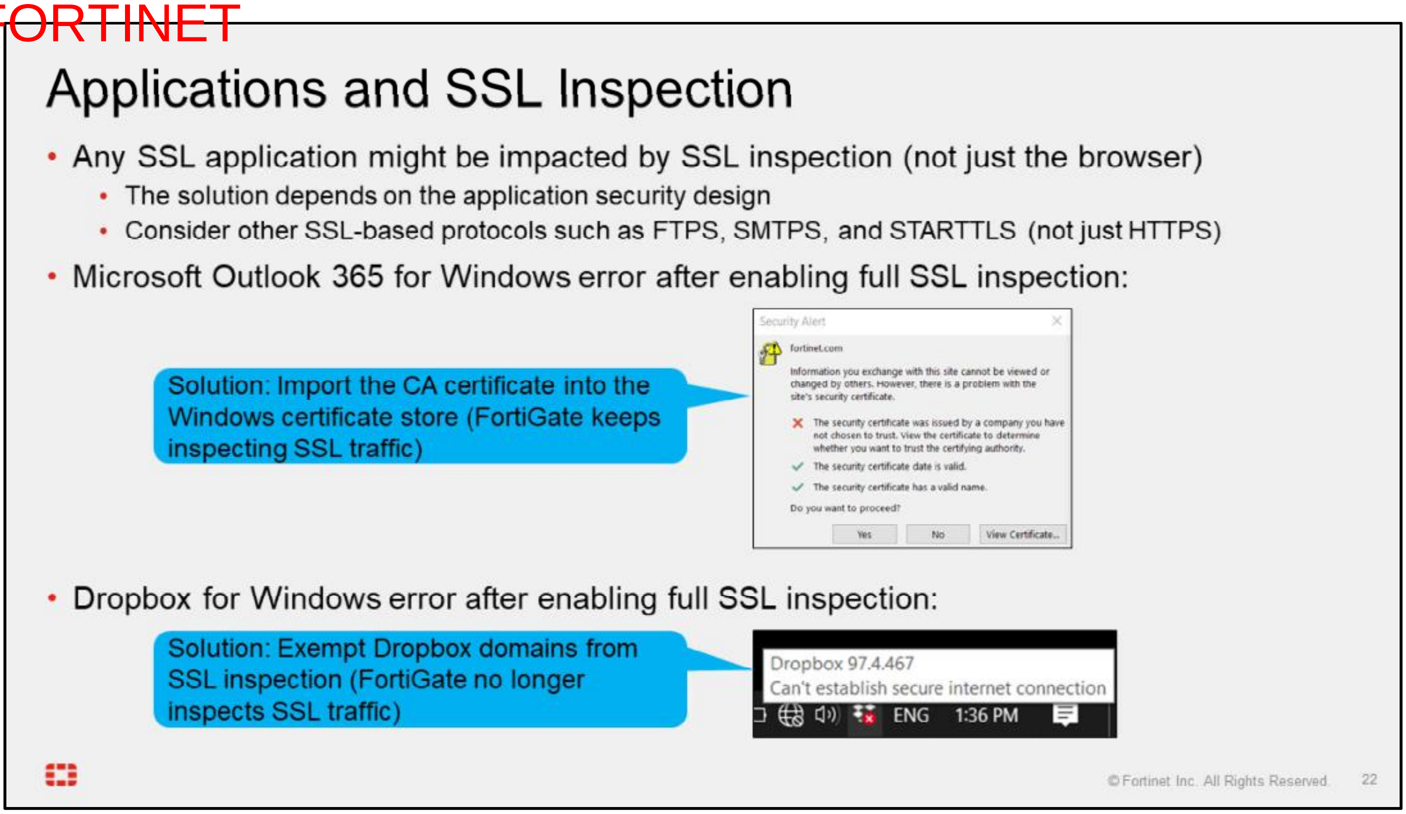
When Alice attempts to connect to the protected server, FortiGate becomes a surrogate web server by establishing a secure connection with the client using the server key pair. FortiGate also establishes a secure connection with the server but acting as a client. This configuration allows FortiGate to decrypt the data from either direction, scan it, and if it is clean, reencrypt it and send it to the intended recipient.

You must install the server certificate and private key, plus the chain of certificates required to build the chain of trust. FortiGate sends the chain of certificates to the browser for this purpose.



By creating a full SSL inspection profile on inbound traffic, you can configure the profile to use multiple websites if they are accessible by the same external IP address. When FortiGate receives client and server hello messages, it selects the certificate to perform the full SSL inspection based on the server name indication (SNI) value compared to the common name (CN) on the certificate part of the inspection profile. If a certificate CN matches the SNI on the request, FortiGate then selects this certificate to replace the original certificate and uses it to inspect the traffic.

If the SNI does not match the CN in the certificate list in the SSL profile, FortiGate selects the first server certificate in the list.

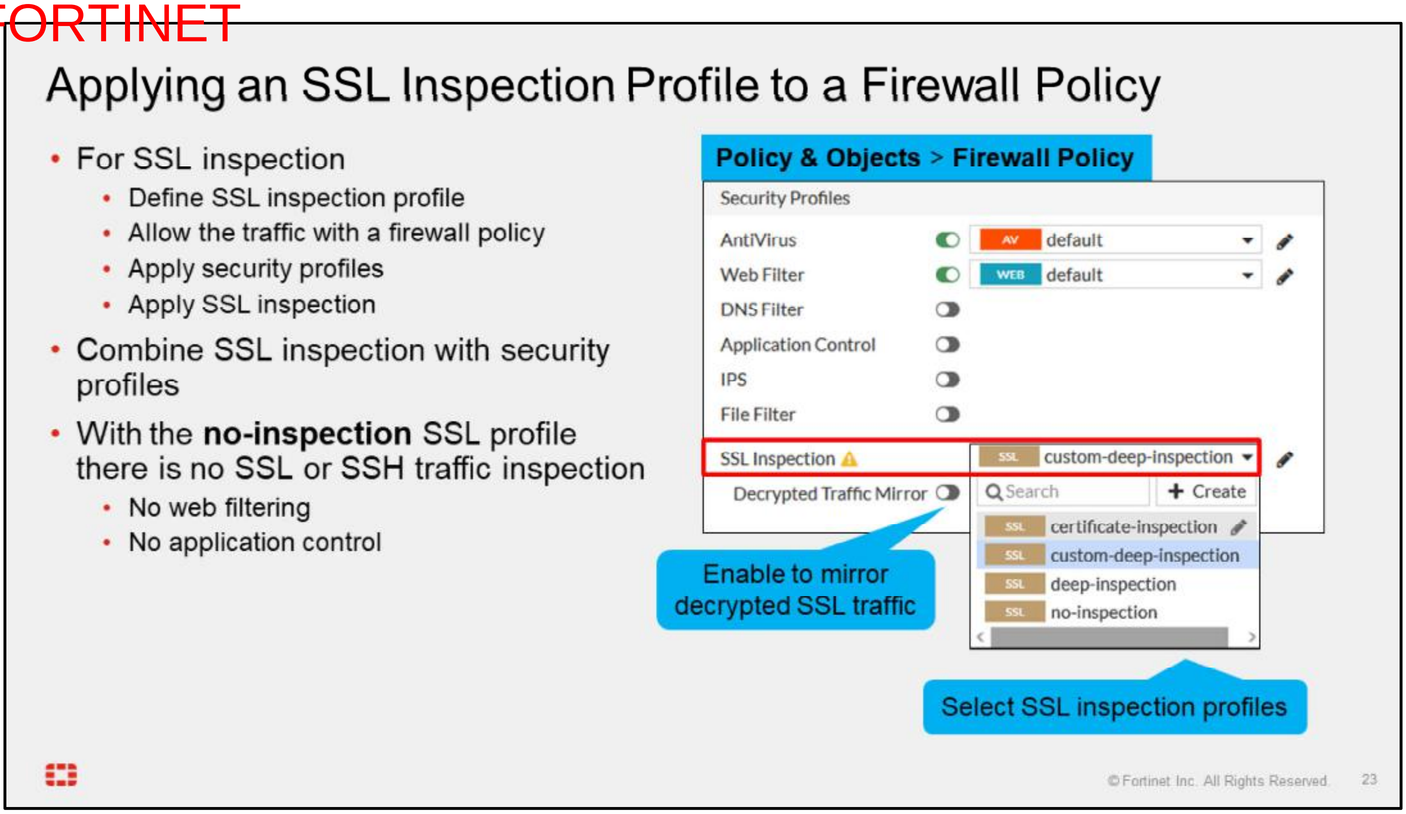


More and more applications are using SSL to securely exchange data over the internet. While most of the content in this lesson centers around the operation and impact of SSL inspection on browsers, the same applies to other applications using SSL as well. After all, the browser is just another application using SSL on your device.

For this reason, when you enable SSL inspection on FortiGate, you need to consider the potential impact on your SSL-based applications. For example, Microsoft Outlook 365 for Windows reports a certificate error when you enable full SSL inspection because the CA certificate used by FortiGate is not trusted. To solve this issue, you can import the CA certificate into your Windows certificate store as a trusted root certificate authority. Because Microsoft Outlook 365 trusts the certificates in the Windows certificate store, the application won't report the certificate error anymore. Another option is to exempt your Microsoft Exchange server addresses from SSL inspection. While this prevents the certificate error, you are no longer performing SSL inspection on email traffic.

There are other applications that have built-in extra security checks that prevent man-in-the-middle attacks, such as HSTS. For example, Dropbox uses certificate pinning to ensure that no SSL inspection is possible on user traffic. As a result, when you enable full SSL inspection on FortiGate, your Dropbox client stops working and reports that it can't establish a secure connection. In the case of Dropbox, the only way to solve the connection error is by exempting the domains that Dropbox connects to from SSL inspection.

In addition, remember that SSL is leveraged by different protocols, not just HTTP. For example, there are other SSL-based protocols such as FTPS, POP3S, SMTPS, STARTTLS, LDAPS, and SIP TLS. If you have an application using any of these SSL-based protocols, and you have turned on SSL inspection along with a security profile that inspects those protocols, then the applications may report an SSL or certificate error. The solution depends on the security measures adopted by the application.

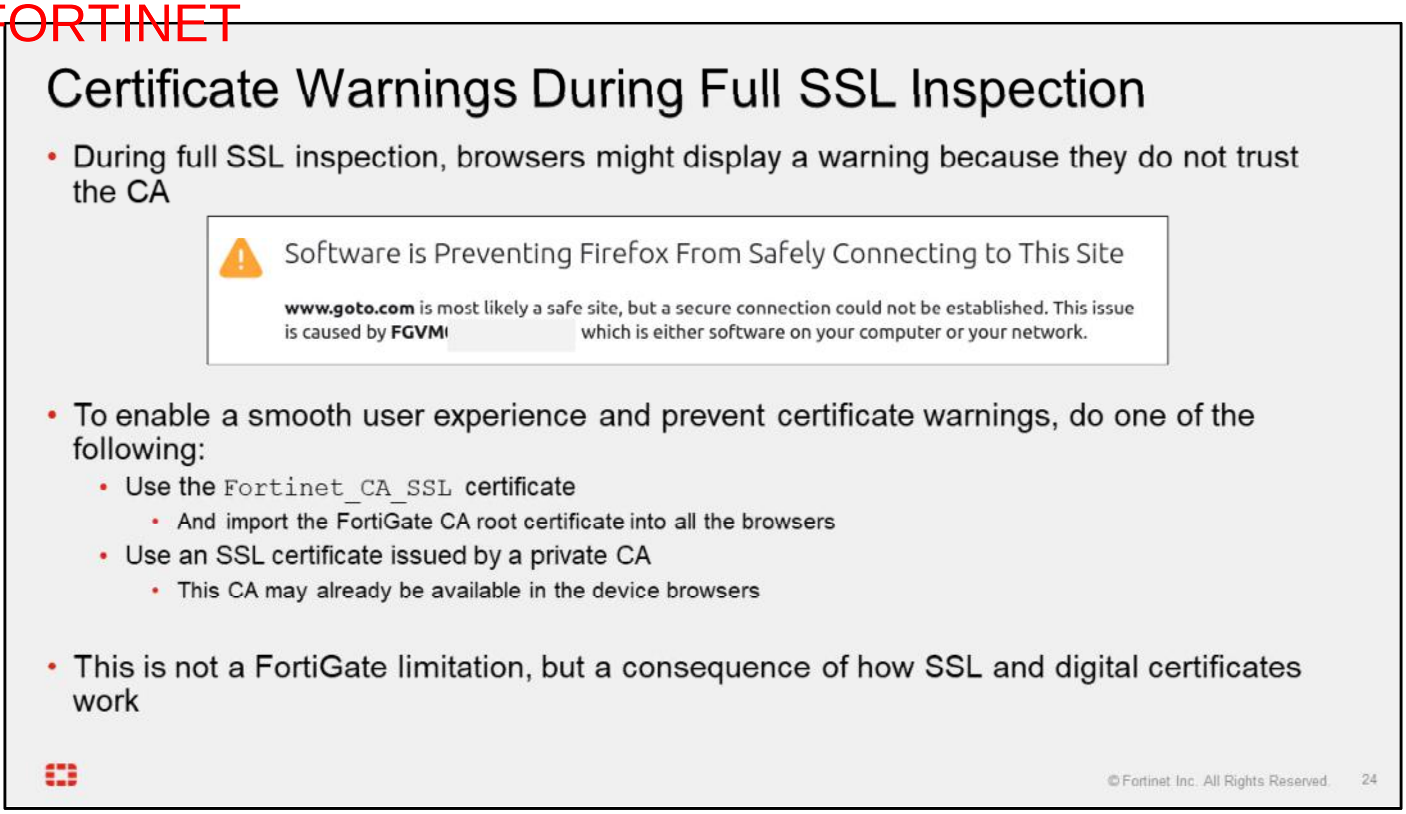


To perform SSL inspection on traffic flowing through the FortiGate device, you must allow the traffic with a firewall policy and apply an SSL inspection profile to the policy. Note than an SSL inspection profile alone will not trigger a security inspection. You must combine it with other security profiles like **Antivirus**, **Web Filter**, **Application Control**, or **IPS**.

By default, firewall policies are set with the **no-inspection** SSL profile. Therefore, any encrypted traffic flows through uninspected. For instance, with the **no-inspection** profile, FortiGate cannot perform any web filtering for HTTPS traffic. To allow web filtering, DNS filtering, or application control for HTTPS traffic, you *must* select an SSL inspection profile with certificate inspection or a deep inspection enabled. For antivirus or IPS control, you should use a deep-inspection profile.

You can see a warning sign near the SSL inspection profile selection menu on the GUI. You will see this warning each time you select an SSL inspection profile with deep inspection. It is there to alert you to the certificate warning that can appear on the user browser when traffic is allowed with this policy. If you hover over the warning sign you can read this message: “This SSL profile uses full SSL inspection. End users will likely see certificate warnings unless the certificate is installed in their browser.”

If you select a profile with full SSL inspection enabled, the option **Decrypted Traffic Mirror** appears. Enable this option if you want FortiGate to send a copy of the decrypted SSL traffic to an interface. It works with both flow-based and proxy-based inspection. When you enable **Decrypted Traffic Mirror**, FortiGate displays a window with the terms of use for this feature. The users must agree to the terms before they can use the feature. You will apply an SSL profile to a firewall policy the same way for inbound or outbound traffic flow inspection. It is the SSL profile applied that specifies the certificate in use when the FortiGate device reencrypts the traffic.

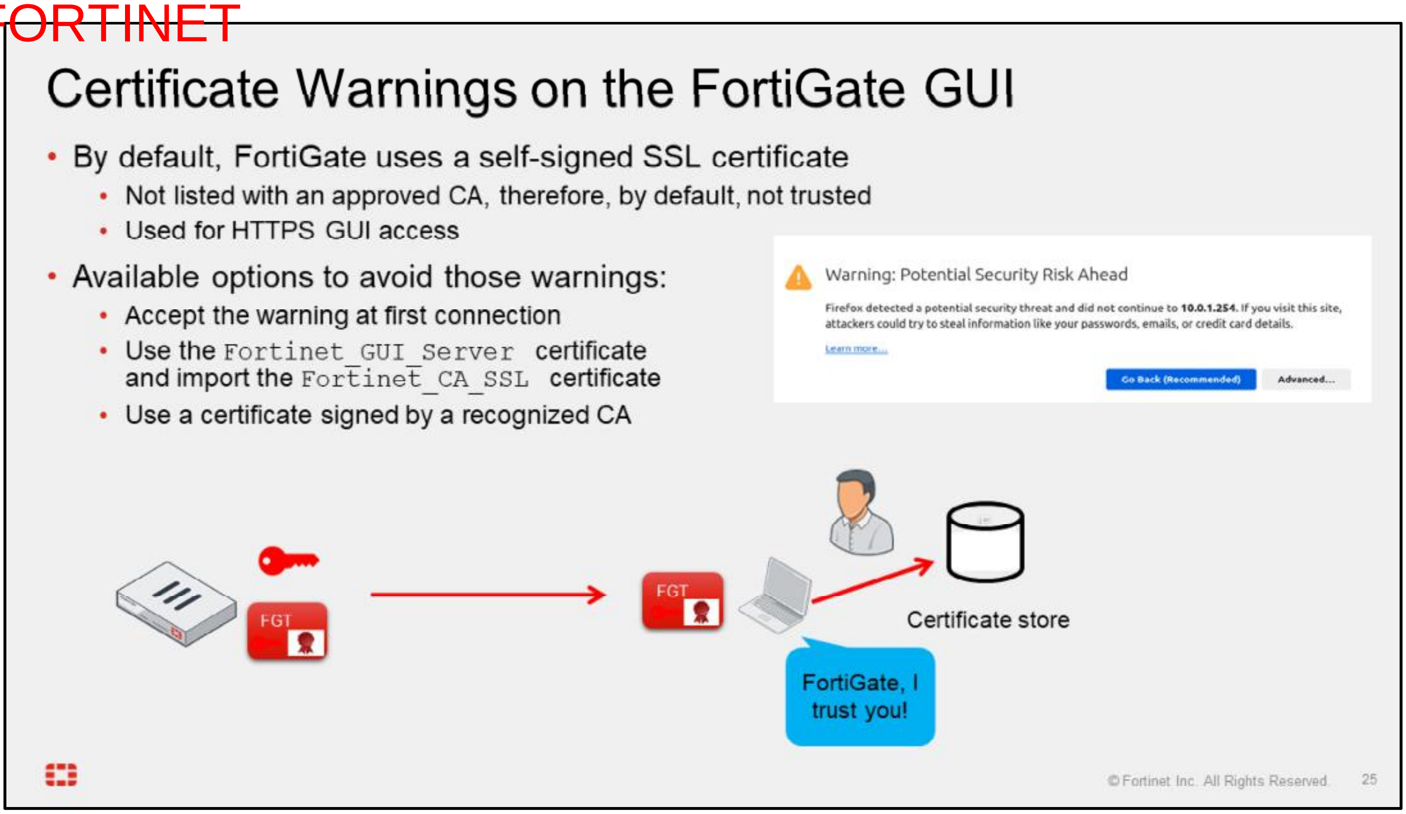


When doing full SSL inspection using the FortiGate self-signed CA, your browser might display a certificate warning each time you connect to an HTTPS site. This is because the browser is receiving certificates signed by FortiGate, which is a CA it does not know and trust. This is not a limitation of FortiGate, but a consequence of how digital certificates are designed to work.

There are two ways to avoid those warnings:

- The first option is to download the default FortiGate certificate for SSL proxy inspection and install it on all the workstations as a trusted root authority.
- The second option is to generate a new SSL proxy certificate from a private CA. In this case, the private CA certificate must still be imported into all the browsers.

If you use an SSL certificate signed by a subordinate CA, you must ensure that the entire chain of certificates—from the SSL certificate to the root CA certificate—installed on FortiGate. Verify also that the root CA is installed on all client browsers. This is required for trust purposes. Because FortiGate sends the chain of certificates to the browser during the SSL handshake, you do not have to import the intermediate CA certificates into the browsers.



By default, FortiGate uses a self-signed certificate to authenticate itself to HTTPS clients. Because the corresponding CA certificate is not prepopulated in the certificate stores of client devices, the first HTTPS connection to a FortiGate device triggers a security warning.

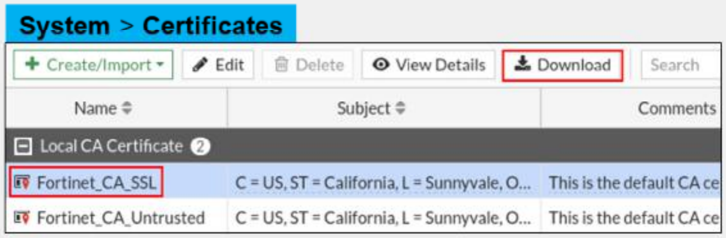
If you trust the FortiGate device and want to keep the self-signed certificate to establish SSL sessions, you can accept the warning and establish the connection. When you accept the warning, your browser imports the FortiGate self-signed certificate into its certificate store. So, the next time you connect to this FortiGate device, your browser already trusts the certificate presented.

Alternatively, you can configure FortiGate to use the `Fortinet_GUI_Server` certificate and add the FortiGate self-signed CA certificate—`Fortinet_CA_SSL`—to the local certificate store of any computer that needs to connect to the FortiGate device. For subsequent connections to the FortiGate GUI interface, those devices trust the certificate and allow connections without warning.

Another option for companies who manage their own CA is to generate a certificate for each of their FortiGate devices and use them to secure HTTPS connections.

Download Private CA Certificates From FortiGate

- Download `Fortinet_CA_SSL` private CA certificate



- Generate a file `Fortinet_CA_SSL.cer`
- Transfer to any computer that requires it

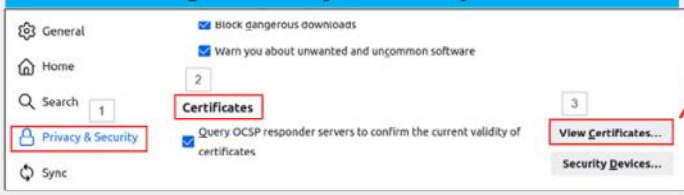
Before you can import the default CA certificate—`Fortinet_CA_SSL`— into the user devices, you must download it from FortiGate.

You can get it from the FortiGate certificate store available under the **System** menu. Upon download, FortiGate generates a `CER` file that you can import into any device, as required.

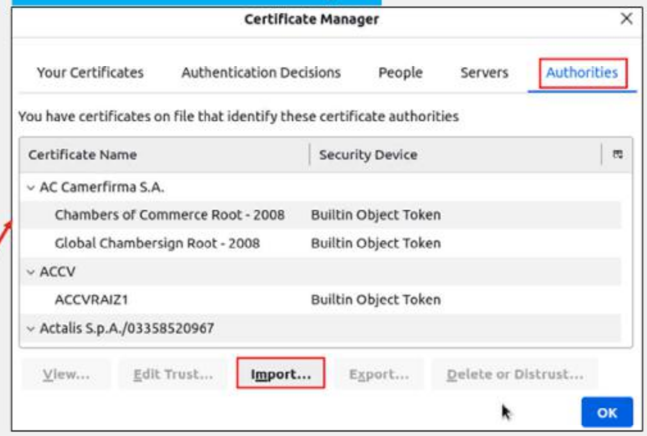
Import Private CA Certificates Into Endpoints

- Import `Fortinet_CA_SSL` private CA certificate into the user device
  - Exact process depends on the OS
  - Example for Linux and Firefox
    - Open the browser setting menu
    - Open the certificate store
    - Import the certificate as a CA

Firefox: **Settings** > **Privacy & Security** > **Certificates**



Firefox: **Certificate Manager**



 27

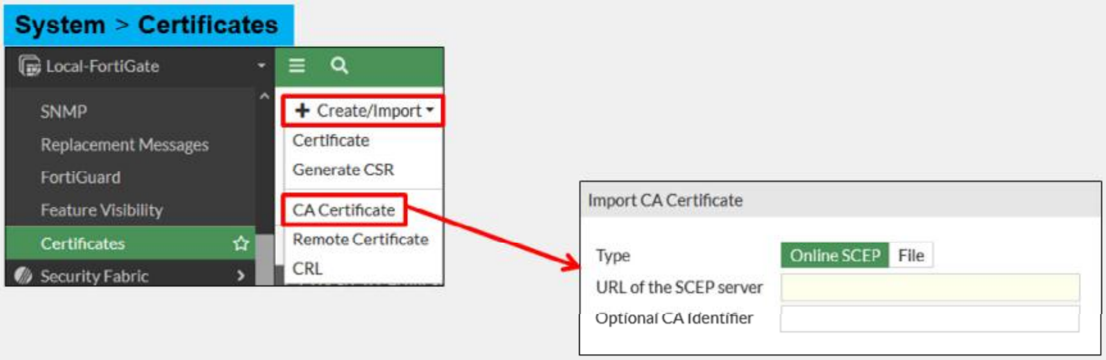
After you download the CA certificate from FortiGate, you can import it into any web browser or operating system. Not all browsers use the same certificate repository. For example, Firefox uses its own repository, while Internet Explorer and Chrome store certificates in a system-wide repository. In order to prevent certificate warnings, you must import the SSL certificate as a trusted root CA.

When you import the certificate, make sure that you save it to the certificate store for root authorities.

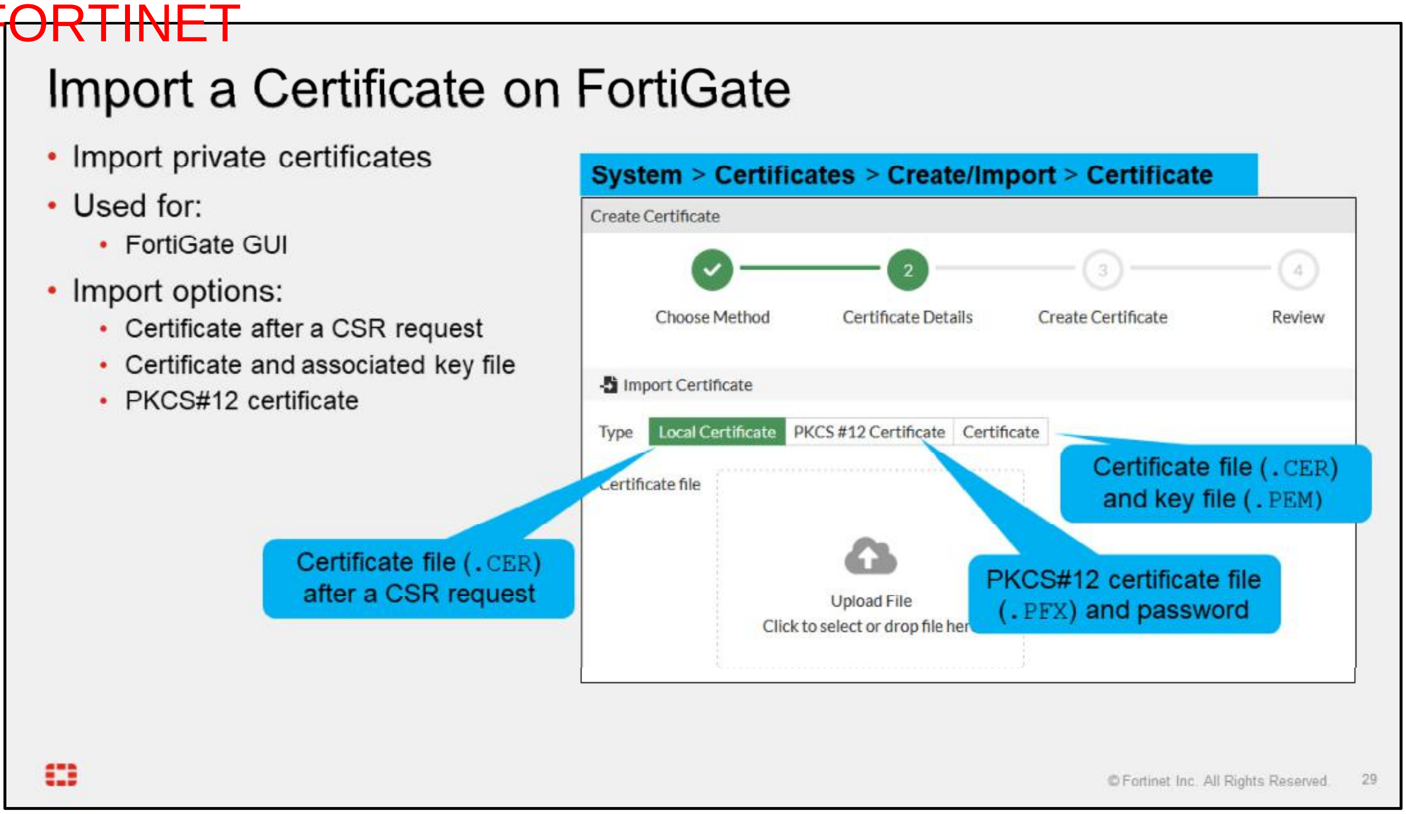
The example on this slide shows the menu you use to import a certificate into the Firefox browser.

Import a CA Certificate on FortiGate

- Import company-owned private CA or CA signed by a certificate authority



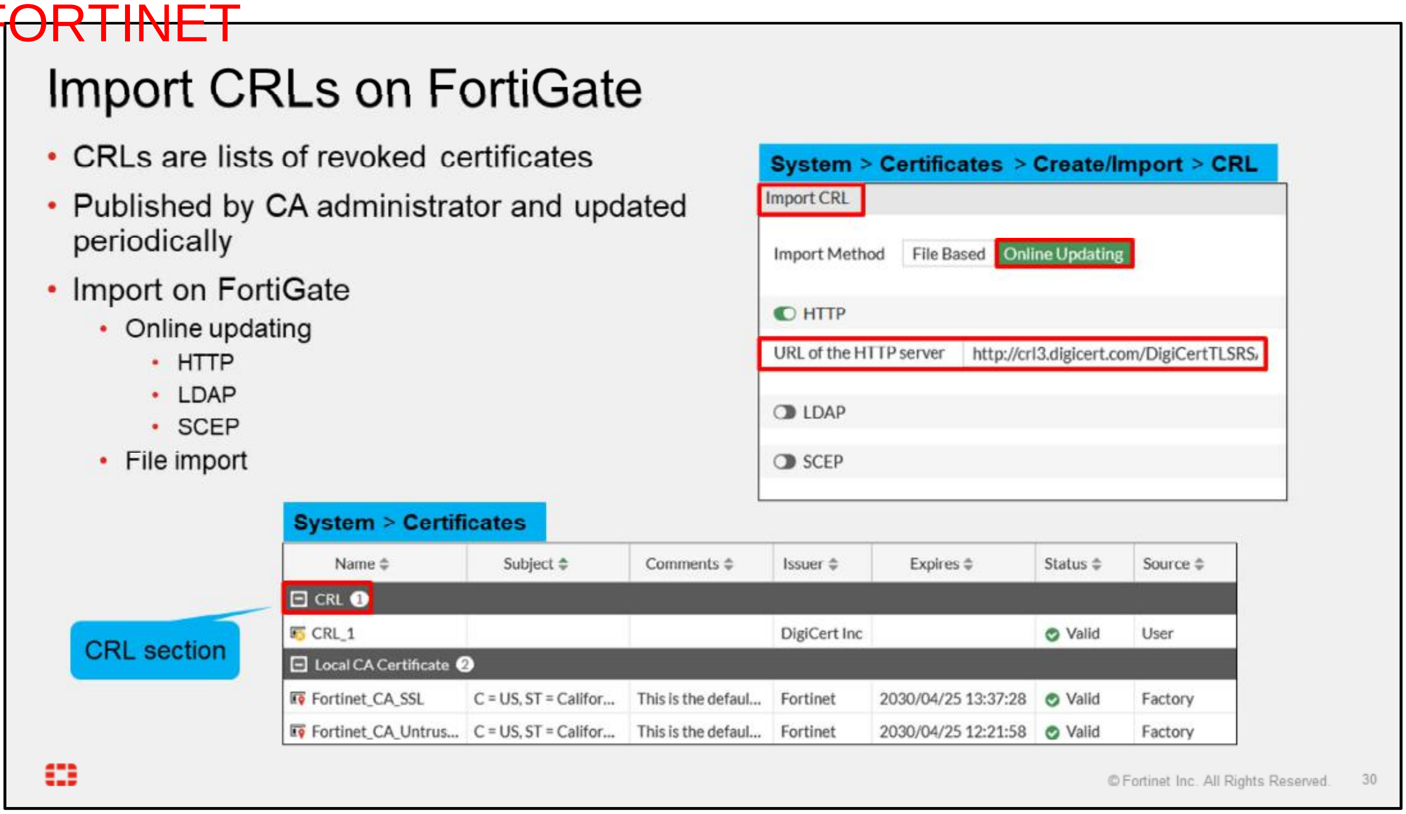
If your company has a private signing CA or a signing CA signed by a certificate authority, you can import the corresponding certificate onto the FortiGate device as shown on this slide. Note that you can import the certificate by connecting to the SCEP server or as a file. SCEP stands for Simple Certificate Enrollment Protocol, and it is a popular and widely available certificate enrollment protocol.



If your company manages its own CA, you can generate certificates for FortiGate GUI access.

FortiGate offers three options to import private certificates:

- You can first generate a certificate signing request (CSR) and submit it to the CA for certificate generation. With this process, the key file is automatically generated and stored on FortiGate when it generates the CSR. Later, you import only the certificate file (CER file) provided by the CA.
- Another option is to import the certificate file and the associated key into the FortiGate certificate store.
- Alternatively, you can load a PKCS#12 certificate file, which is identified as a `PFX` file. It contains the certificate and associated private key.



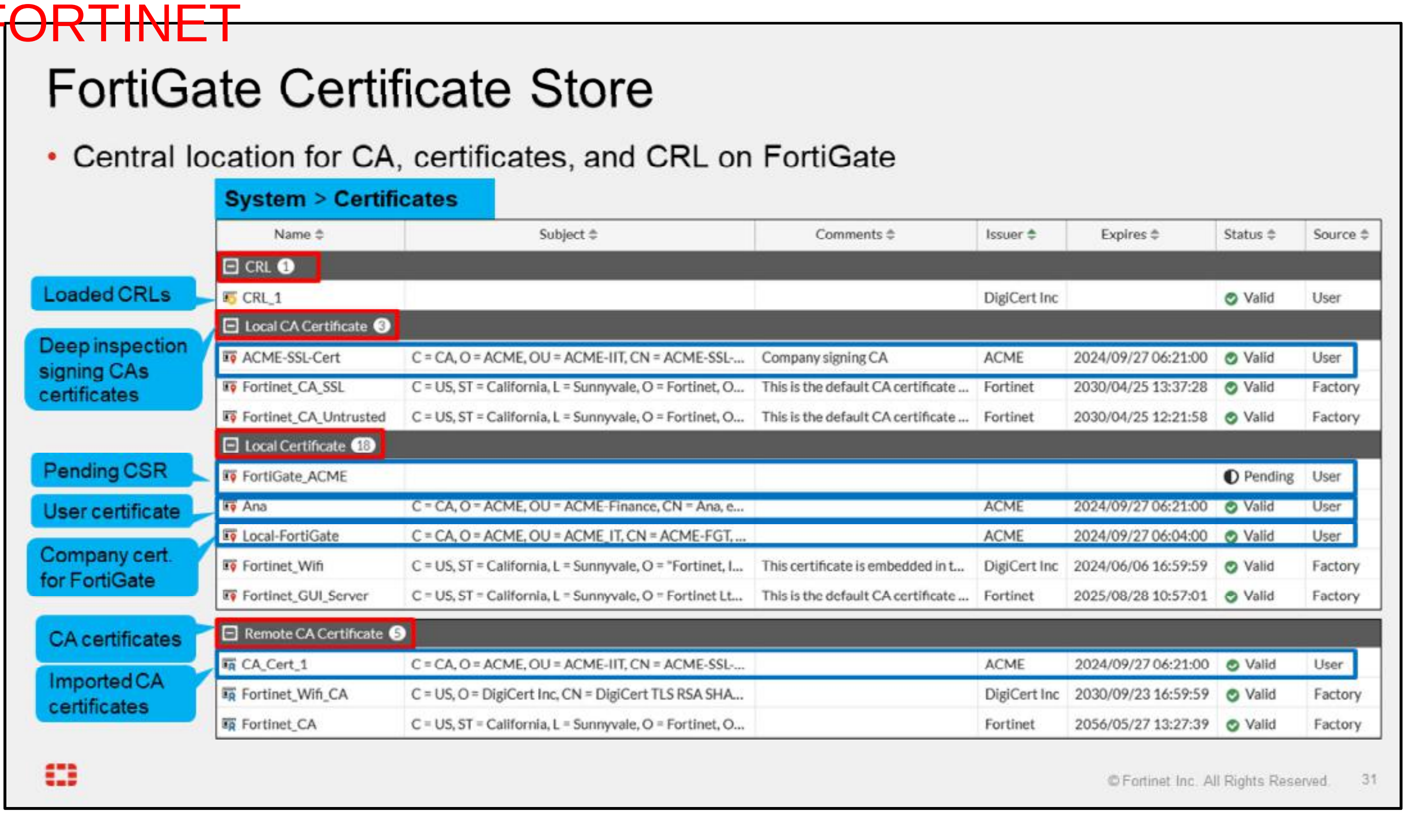
Because it is not possible to recall a certificate, the certificate revocation list (CRL) details certificates signed by valid CAs that should no longer be trusted. Certificates may be revoked for many reasons, such as if the certificate was issued erroneously, or if the private key of a valid certificate has been compromised.

CA administrators publish CRLs and periodically update them. You can load CRLs into the FortiGate device as files provided by CA administrators, or direct FortiGate to connect to the CRL repositories and load the corresponding list.

The recommended method to keep the list of revoked certificates up to date is to load them through one of the following available protocols: HTTP, LDAP, or SCEP. Alternatively, you can load the CRL list into the FortiGate certificate store by importing CRL files.

You can get the CRL distribution point associated with a certificate by editing it and navigating to the CRL endpoints information part.

Note that the CRL section on the FortiGate GUI **Certificates** menu is visible only after you have loaded at least one CRL.



The central location to review the certificates imported into a FortiGate device is the certificate list available in the **Certificates** section of the **System** menu.

In this table you can view:

- The **CRL** section, which contains all loaded CRLs.
- The **Local CA Certificate** section, which contains the FortiGate signing CA certificate. By default, it contains the `Fortinet_CA_SSL` and `Fortinet_CA_untrusted` certificates. If you import a signing CA certificate from your company, it will appear in this section.
- The **Local Certificate** section, which contains device and user certificates. In the example shown on this slide you can see a user certificate, `Ana`, and a device certificate, `Local-FortiGate`. For both, the issuer is ACME, which is the company private CA in this example.
- The **Remote CA** certificate section, which is section where FortiGate displays all imported CA certificates that are not signing CA certificates.

Note that:

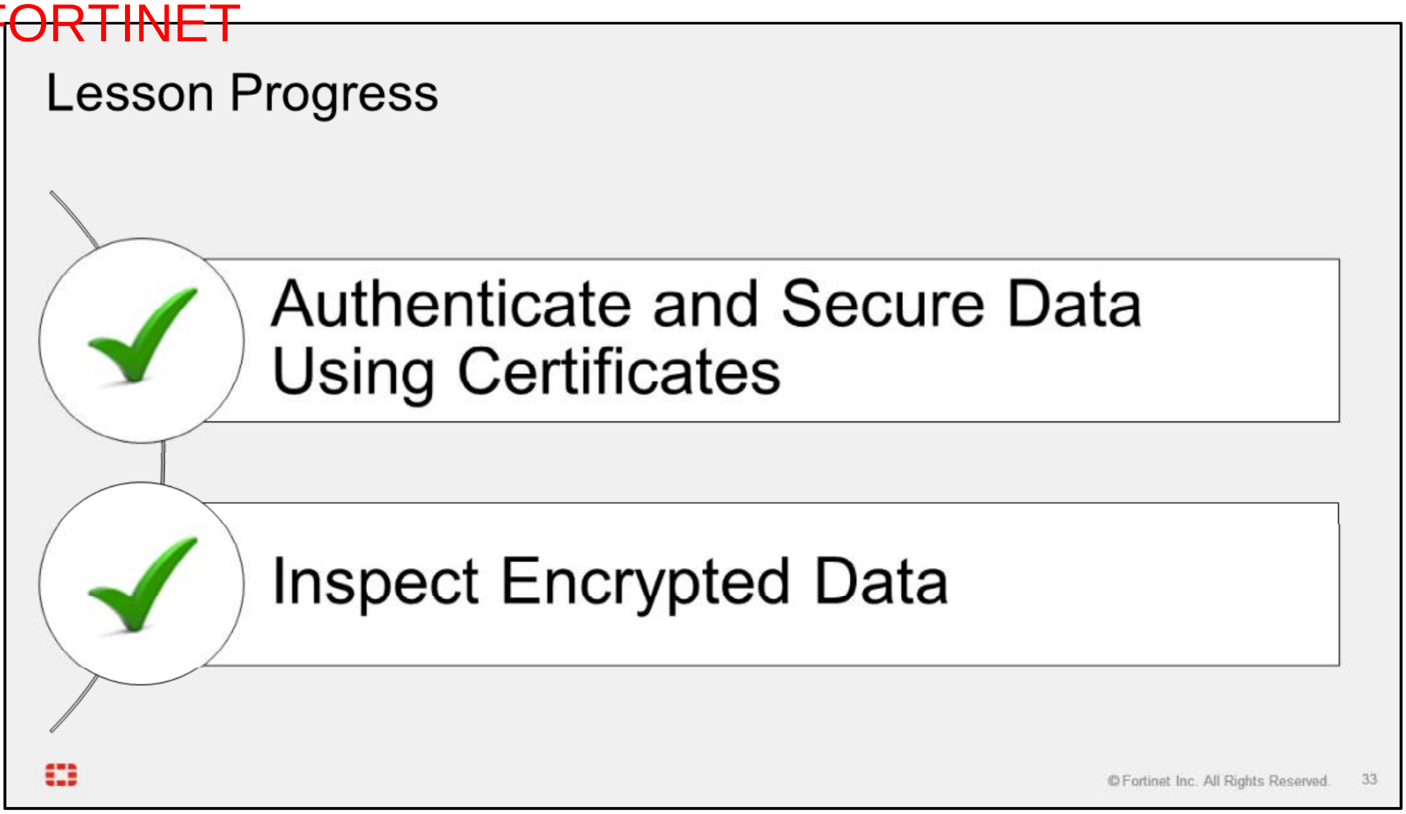
- The **CRL** section is visible only after you have loaded at least one CRL.
- FortiGate displays CRLs only if the corresponding CA certificate is imported into the certificate store.
- FortiGate shows the certificate signing requests (CSR) in the **Local Certificate** section with the status **Pending**.
- The **Source** column indicates the origin of the certificate, either **Factory** for certificates always present or **User** for certificates imported by an administrator user.

Knowledge Check

1. What is the most common reason for a certificate error if full SSL inspection is enabled on a Windows application?
   - ✓ A. The FortiGate CA certificate is not trusted.
   - B. The certificate is listed in the CRL.

2. Which SSL inspection profile must be used if FortiGate is used for antivirus or IPS control?
   - A. Certificate inspection
   - ✓ B. Deep inspection

 32



Congratulations! You have completed this lesson.

Now, you will review the objectives covered in this lesson.

Review

- ✓ Describe why FortiGate uses digital certificates
- ✓ Describe how FortiGate uses certificates to authenticate users and devices
- ✓ Describe how FortiGate uses certificates to ensure the privacy of data
- ✓ Describe SSL inspection on FortiGate
- ✓ Identify invalid certificates
- ✓ Describe import certificates on FortiGate

 34

This slide shows the objectives that you covered in this lesson.

By mastering the objectives covered in this lesson, you learned how FortiGate uses certificates and how to manage and work with certificates in your network.